ENGLISH FOR WORK / DETECTION / RESPONSE / ACCESS / RISK

Cybersecurity English

Report the evidence. Explain the exposure.



Phil Stilwell

© 2026 Phil Stilwell. All rights reserved.
No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means without prior written permission from the author, except as permitted by law.

Eight practical lessons. Eleven extended conversations.
Vocabulary, phrase banks, guided speaking, and explained answers.

Revised 2026 edition / Upper-intermediate to advanced

Your route through the book

01 Security Triage and Alert Investigation, page 4

Give a concise alert handoff that separates logged events, plausible explanations, and unresolved authorization.

02 Incident Response and Containment, page 16

Coordinate a response update with action status, operational impact, evidence preservation, and a defined next report.

03 Vulnerability Management, page 29

Explain a risk-based remediation order without treating severity scores as complete business-risk assessments.

04 Identity, Access, and Least Privilege, page 40

Negotiate a specific access arrangement using identity, task, permission, duration, approval, and accountability.

05 Threat Modeling and Secure Design, page 54

Trace a data flow, identify a trust boundary, and turn a specific abuse case into a testable design requirement.

06 Governance, Risk, and Compliance, page 67

Describe audit evidence, distinguish missing proof from proven failure, and state the actual closure conditions.

07 Security Awareness and Phishing, page 81

Elicit a precise suspicious-message report, encourage prompt disclosure, and avoid requests for secrets or unsupported reassurance.

08 Executive Risk Briefings, page 91

Connect a measured security gap to a business consequence and a specific investment request without claiming guaranteed risk elimination.

Professional communication notes, page 3

Three additional workplace cases, page 107

Answers and explanations, page 118

Phrase finder, page 176

Vocabulary index, page 178

References and publication notes, page 183

Suggested study range: B2-C1. This is an editorial study range, not a certified proficiency assessment.

Precision matters before certainty arrives.

Security teams often speak while the evidence is incomplete. An unusual login is not automatically an intrusion; a containment action is not proof of recovery. These conversations practice the language needed to act promptly while keeping observations, hypotheses, authority, and business consequences distinct.

Name the evidence first

Give the source, event time, and observed behavior before the interpretation. Preserve uncertainty without hiding the need to act.
"The log records a successful sign-in; authorization is not yet verified."

Bound a negative finding

A search result applies to the sources and period actually checked. Missing records cannot prove that nothing happened.
"We found no matching event in the available application logs."

Separate action from outcome

Proposed, approved, completed, and verified describe different states. Identify who can authorize a disruptive response.
"Isolation is complete; eradication and recovery are not yet confirmed."

Translate risk into a decision

Connect a specific exposure to a plausible business consequence, then state the requested action and what remains uncertain.
"The proposal addresses delayed payroll recovery, not every cyber risk."

Professional boundaries

Original fictional English practice, not a security certification, incident-response playbook, legal opinion, or authorization to test systems. Follow the responsible team, approved procedures, evidence-handling rules, and applicable requirements. All organizations, incidents, figures, priorities, and control criteria in the cases are invented.

A Read the situation

LESSON 01 / SECURITY TRIAGE AND ALERT INVESTIGATION

Give a concise alert handoff that separates logged events, plausible explanations, and unresolved authorization.

> **A successful login is not verified authorization**
>
> Analyst Anika reviews alert S14 with shift lead Luis. The identity log records a successful privileged-account sign-in at 02:14 UTC from an unfamiliar address. A maintenance ticket covers 02:00-03:00 UTC, but its host and account have not been matched to the event. The account owner has not replied. Application logs are missing for 02:10-02:20 UTC. No malicious action is confirmed. The local process requires escalation to Luis now while correlation continues.

People: Anika, Security analyst; Luis, Shift lead.

Read the record

Choose one answer per question using the facts above.

1. What does the identity log establish?

A. A verified match to the maintenance ticket
B. Complete application visibility
C. A successful privileged-account sign-in at 02:14 UTC
D. A confirmed hostile actor

2. What is missing from 02:10-02:20 UTC?

A. Application logs
B. Every identity record
C. The maintenance ticket
D. The alert identifier

3. What does the local process require now?

A. Calling the account owner malicious
B. Escalation to Luis while correlation continues
C. Closure because maintenance was scheduled
D. Waiting for certainty before informing anyone

Answers and explanations, page 118

B Vocabulary in use

CORE TERMS

alert
A notification that a detection condition was met.
triage an alert

event
An observable occurrence recorded by a system.
correlate events

incident
An occurrence assessed as compromising or threatening security.
classify an incident

triage
Initial assessment to decide priority and next handling.
perform security triage

privileged account
An identity with elevated system permissions.
review privileged-account activity

successful sign-in
A recorded completion of an authentication process.
verify a successful sign-in

authentication
Checking evidence that an identity claim is valid.
examine authentication records

authorization
Permission for a particular action or resource.
confirm authorization

source address
A network address associated with an observed connection.
investigate a source address

timestamp
A recorded time associated with an event.
preserve the timestamp

UTC
Coordinated Universal Time, a shared time reference.
report times in UTC

maintenance window
A defined period for planned maintenance work.
confirm the maintenance window

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

alert ALERT

triage an alert

Keep the meaning precise: A notification that a detection condition was met.

successful sign-in SUCCESSFUL SIGN-IN

verify a successful sign-in

Keep the meaning precise: A recorded completion of an authentication process.

B Precision and professional shorthand

EXTEND YOUR RANGE

correlation

Relating records to assess whether events are connected.

correlate identity and host logs

log source

A system or service producing event records.

identify the log source

telemetry

System observations collected for monitoring or analysis.

review available telemetry

visibility gap

A period or area lacking needed observation data.

disclose a visibility gap

baseline

A reference pattern used to evaluate current behavior.

compare activity with the baseline

anomaly

A departure from an expected pattern.

investigate an anomaly

false positive

A detection that incorrectly indicates the target condition.

validate a false positive

benign activity

Activity assessed as not harmful in its context.

confirm benign activity

indicator

An observable sign that can support an investigation.

assess an indicator

hypothesis

A proposed explanation awaiting evaluation.

test the maintenance hypothesis

confidence level

A qualified assessment of evidential strength.

state the confidence level

case record

A documented account of observations and handling.

update the case record

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

maintenance window MAINTENANCE WINDOW

confirm the maintenance window

Keep the meaning precise: A defined period for planned maintenance work.

baseline BASELINE

compare activity with the baseline

Keep the meaning precise: A reference pattern used to evaluate current behavior.

C Phrases that move the work forward

Lead with the event
"The identity log records a successful sign-in at 02:14 UTC."

Separate the conclusion
"Authorization is not yet verified."

Limit the match
"We have not matched the host and account."

Avoid an accusation
"Who can confirm the authorized operator?"

State uncertainty
"No malicious action is confirmed at this point."

Use neutral wording
"The address is unfamiliar, not yet classified as hostile."

Keep time consistent
"Both timestamps are reported in UTC."

Name the next check
"We will compare the ticket, account, and host."

Identify the privilege
"The event involves a privileged account."

Name the plausible explanation
"The timing overlaps planned maintenance."

Identify missing evidence
"Application logs are missing for ten minutes."

Preserve urgency
"I am escalating while correlation continues."

Bound the search
"That conclusion applies only to the sources checked."

Ask for a record
"Please provide the relevant maintenance approval."

Reject premature closure
"The maintenance window alone does not close the alert."

Close the handoff
"S14 remains under investigation with a documented visibility gap."

Precision in real exchanges

Purpose: Name the plausible explanation
Useful wording: "The timing overlaps planned maintenance."

Purpose: Limit the match
Useful wording: "We have not matched the host and account."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which handoff best fits S14?

A. Successful privileged sign-in; authorized maintenance; application-log gap; awaiting closure.

B. Successful privileged sign-in; authorization unverified; complete application visibility; escalated.

C. Successful privileged sign-in; authorization unverified; application-log gap; escalation deferred until the owner replies.

D. Successful privileged sign-in; authorization unverified; application-log gap; escalated for investigation.

2. Which record would help test the maintenance explanation?

A. A ticket matching this host, account, and authorized task

B. A ticket from a different server at any time

C. The owner's seniority alone

D. The alert's red display color

3. A colleague needs the term for this meaning: Initial assessment to decide priority and next handling. Which term fits?

A. source address

B. indicator

C. triage

D. telemetry

D Choose the response that fits / continued

4. Rebuild the exchange from "A successful login is not verified authorization". Anika: "I nearly waited for the owner to reply before calling you. Should I escalate now and keep the maintenance explanation provisional?" Luis: [missing response] Anika: "I also found missing application logs between two ten and two twenty UTC. That interval includes the identity event we are discussing." Which response belongs in the gap?

A. Record the visibility gap explicitly. We cannot use an incomplete application search to say that nothing happened after the sign-in, even if the records we have look ordinary.

B. Start with the event, then tell me what remains unknown. A successful sign-in matters, but I do not want the handoff to imply confirmed hostile activity.

C. Keep triage moving. Our process requires escalation now, and your uncertainty belongs in the update. We can investigate without accusing the owner or announcing a confirmed intrusion.

D. Then maintenance is a hypothesis, not a closure reason. We need the actual task, operator, and asset match before describing this particular sign-in as approved work.

Answers and explanations, page 118

> **One useful distinction**
>
> A successful authentication does not establish that the account holder intended or authorized the action. A matching time window supports a possible maintenance explanation, not a confirmed match to this event.

E Conversation

A successful login is not verified authorization

A successful login is not verified authorization

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

event / anomaly / correlation / authentication / confidence level / hypothesis / authorization / visibility gap / triage / case record

01 **Anika:** S14 triggered on a privileged sign-in at two fourteen UTC. The address is unfamiliar. I have the identity record, but not an explanation yet.

02 **Luis:** Start with the [1] _____, then tell me what remains unknown. A successful sign-in matters, but I do not want the handoff to imply confirmed hostile activity.

03 **Anika:** There is a maintenance ticket from two to three UTC. The timing overlaps, although I have not matched its host or account to this record.

04 **Luis:** Then maintenance is a [2] _____, not a closure reason. We need the actual task, operator, and asset match before describing this particular sign-in as approved work.

05 **Anika:** I nearly waited for the owner to reply before calling you. Should I escalate now and keep the maintenance explanation provisional?

06 **Luis:** Keep [3] _____ moving. Our process requires escalation now, and your uncertainty belongs in the update. We can investigate without accusing the owner or announcing a confirmed intrusion.

E Conversation / continued

07 **Anika:** I also found missing application logs between two ten and two twenty UTC. That interval includes the identity event we are discussing.

08 **Luis:** Record the [4] _____ explicitly. We cannot use an incomplete application search to say that nothing happened after the sign-in, even if the records we have look ordinary.

09 **Anika:** The dashboard says new address. Is that enough to label the source hostile, or should I just report that it is unfamiliar?

10 **Luis:** Call it an [5] _____. It deserves investigation, but novelty does not establish who controlled the connection. The maintenance explanation still needs testing, just as the hostile explanation does.

Conversation continues on the next page.

A successful login is not verified authorization

CONVERSATION / CONTINUED

11 **Anika:** Understood. I will say that the identity log records success, the source is unfamiliar, and the account holder has not confirmed the activity.

12 **Luis:** Separate [6] _____ from permission. The recorded login result does not establish that the operator was entitled to perform the particular task at that time.

13 **Anika:** I will request the relevant approval through our internal channel. The ticket number alone is not enough without checking which account and host it covers.

14 **Luis:** Exactly. We need [7] _____ evidence tied to the action. Keep the original event details and identify any later corrections instead of silently rewriting the first report.

15 **Anika:** For the next shift, I will list the identity record, maintenance ticket, unanswered owner request, and missing application interval together in S14.

16 **Luis:** Put that in the [8] _____. The next analyst should see both the current evidence and the reason this alert remains open, without reconstructing the conversation.

17 **Anika:** I will compare the ticket against the host and account, then update the working explanation when that evidence arrives. No malicious action is confirmed.

18 **Luis:** Describe your [9] _____ carefully. We have a real observation and unresolved context. Repeating the same possibility does not turn it into stronger evidence.

19 **Anika:** My handoff will keep the event time in UTC and state that the missing application records limit our ability to exclude later activity.

20 **Luis:** Good. Continue the [10] _____ and keep me involved under the escalation process. The status is under investigation, with authorization unverified and the visibility limitation clearly recorded.

CHECK THE GAPS

1. event / **2.** hypothesis / **3.** triage / **4.** visibility gap / **5.** anomaly / **6.** authentication / **7.** authorization / **8.** case record / **9.** confidence level / **10.** correlation

Why these answers fit, page 119

F Check accuracy and scope

A successful login is not verified authorization

Return to the case

Analyst Anika reviews alert S14 with shift lead Luis. The identity log records a successful privileged-account sign-in at 02:14 UTC from an unfamiliar address. A maintenance ticket covers 02:00-03:00 UTC, but its host and account have not been matched to the event. The account owner has not replied. Application logs are missing for 02:10-02:20 UTC. No malicious action is confirmed. The local process requires escalation to Luis now while correlation continues.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. Why is the log gap relevant?

A. It proves the actor deleted all records.
B. It changes UTC into local time.
C. It makes the successful sign-in disappear.
D. It limits what the team can exclude about application activity.

2. Which wording avoids premature blame?

A. The account was used; the operator is not yet verified.
B. The account owner attacked the system.
C. The owner must have approved the activity.
D. Every unfamiliar address is malicious.

Answers and explanations, page 121

Listen for the distinction

Switch roles for turns 11-20. Keep authentication distinct from authorization.

Ask without accusing

A direct question about who authorized an action is a request for evidence, not necessarily an accusation. Use event details and neutral verbs. Neither familiarity with a colleague nor an urgent alert label settles whether a particular action was permitted.

F Say it / transfer to a new case

Overlap is still not a match

Alert T8 records a sign-in at 05:20 UTC. Maintenance was scheduled from 05:00-06:00, but the account match is unverified. Application logs are unavailable. The shift lead has received the escalation.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

unavailable / UTC / unverified / received

01 **Analyst:** The event time is 05:20 [1] _____.

02 **Lead:** The account match remains [2] _____.

03 **Analyst:** Application logs are [3] _____.

04 **Lead:** The escalation has been [4] _____.

CHECK THE GAPS

1. UTC / **2.** unverified / **3.** unavailable / **4.** received

Why these answers fit, page 121

F Say it / transfer to a new case / continued

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "A successful login is not verified authorization". Anika: "I will request the relevant approval through our internal channel. The ticket number alone is not enough without checking which account and host it covers." Luis: [missing response] Anika: "For the next shift, I will list the identity record, maintenance ticket, unanswered owner request, and missing application interval together in S14." Which response belongs in the gap?

A. Start with the event, then tell me what remains unknown. A successful sign-in matters, but I do not want the handoff to imply confirmed hostile activity.

B. Then maintenance is a hypothesis, not a closure reason. We need the actual task, operator, and asset match before describing this particular sign-in as approved work.

C. Exactly. We need authorization evidence tied to the action. Keep the original event details and identify any later corrections instead of silently rewriting the first report.

D. Put that in the case record. The next analyst should see both the current evidence and the reason this alert remains open, without reconstructing the conversation.

Answers and explanations, page 122

A Read the situation

LESSON 02 / INCIDENT RESPONSE AND CONTAINMENT

Coordinate a response update with action status, operational impact, evidence preservation, and a defined next report.

> **Isolation is complete; the investigation is not**
>
> Incident coordinator Mara briefs service owner Joel about suspected unauthorized activity on billing host B7, first reported at 09:10 UTC. Under the approved playbook, Mara authorized network isolation at 09:18; completion was verified at 09:22. Billing jobs are paused. Investigators are preserving available evidence; cause, data access, and wider scope remain unconfirmed. Restoration requires the response lead and service owner under the local process. The next update is due at 09:45, not a promised restoration time.

People: Mara, Incident coordinator; Joel, Billing service owner.

Read the record

Choose one answer per question using the facts above.

1. When was isolation completion verified?

A. 09:45 UTC
B. 09:22 UTC
C. 09:10 UTC
D. 09:18 UTC

2. What is the confirmed operational impact?

A. All customer records were stolen.
B. Every service is unavailable.
C. Billing has been fully restored.
D. Billing jobs are paused.

3. What does 09:45 represent?

A. The proven intrusion start
B. Automatic closure
C. The next update time
D. A guaranteed restoration time

Answers and explanations, page 123

B Vocabulary in use

CORE TERMS

incident response
Coordinated handling of a suspected or confirmed security incident.

coordinate incident response

network isolation
Restricting a system's network connections.

confirm network isolation

recovery
Restoring affected capabilities under the required checks.

authorize recovery

service owner
The role responsible for a business or technical service.

involve the service owner

action log
A time-ordered record of response actions.

maintain the action log

chain of custody
Documentation of evidence handling and transfers.

maintain chain of custody

containment
Action intended to limit incident spread or impact.

verify containment actions

eradication
Removal of incident causes or persistence as applicable.

verify eradication

response lead
The person directing the assigned response process.

brief the response lead

playbook
Agreed guidance for handling a defined situation.

follow the approved playbook

evidence preservation
Protecting relevant records and artifacts from loss or alteration.

coordinate evidence preservation

volatile data
Information that may be lost when system state changes.

preserve volatile data appropriately

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

incident response INCIDENT RESPONSE

coordinate incident response

Keep the meaning precise: Coordinated handling of a suspected or confirmed security incident.

response lead RESPONSE LEAD

brief the response lead

Keep the meaning precise: The person directing the assigned response process.

B Precision and professional shorthand

EXTEND YOUR RANGE

affected host

A system within the known impact or investigation scope.

identify the affected host

incident scope

The systems, accounts, and effects covered by an incident assessment.

establish incident scope

lateral movement

Movement from an initial foothold to other systems.

investigate possible lateral movement

persistence

A means of retaining access across changes or restarts.

assess persistence

exfiltration

Unauthorized transfer of data outside the relevant boundary.

investigate possible exfiltration

restoration criterion

A condition required before returning a service.

confirm restoration criteria

business impact

A consequence for organizational operations or objectives.

report business impact

status update

A time-specific summary of the current position.

issue a status update

decision authority

The role permitted to approve a particular action.

confirm decision authority

handover

Transfer of responsibility and relevant information.

complete the response handover

post-incident review

A review of events and improvements after handling an incident.

schedule a post-incident review

root cause

An underlying reason supported by investigation evidence.

establish the root cause

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

volatile data VOLATILE DATA

preserve volatile data appropriately

Keep the meaning precise: Information that may be lost when system state changes.

exfiltration EXFILTRATION

investigate possible exfiltration

Keep the meaning precise: Unauthorized transfer of data outside the relevant boundary.

C Phrases that move the work forward

State the current impact
"Billing jobs are paused on B7."

Give the first report
"The activity was first reported at 09:10 UTC."

Separate approval from action
"Isolation was authorized at 09:18."

Confirm execution
"Completion was verified at 09:22."

Name the unknown
"The cause and wider scope remain unconfirmed."

Avoid a false all-clear
"Containment does not establish recovery readiness."

Protect the record
"Evidence preservation is in progress."

Assign the decision
"Restoration requires the response lead and service owner."

Bound the statement
"We have not confirmed unauthorized data access."

Commit to communication
"The next update will be at 09:45."

Correct the date meaning
"That is an update time, not a restoration estimate."

Acknowledge disruption
"I recognize the impact on billing operations."

Keep actions traceable
"Please record the authorization and completion separately."

Avoid an improvised change
"Use the response process before changing system state."

Prepare the handover
"Include completed actions, open questions, and owners."

Close with the current status
"B7 is isolated; investigation and recovery assessment continue."

Precision in real exchanges

Purpose: Confirm execution
Useful wording: "Completion was verified at 09:22."

Purpose: Name the unknown
Useful wording: "The cause and wider scope remain unconfirmed."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which timeline is accurate?

A. Isolation complete 09:18 because authorization was given.

B. Incident closed 09:22 because a host was isolated.

C. Report 09:10; isolation authorized 09:18; completion verified 09:22.

D. Intrusion proven to begin 09:10; recovery complete 09:18.

2. Which reply addresses pressure to restore now?

A. Treat the update deadline as automatic permission to reconnect.

B. Say all systems are clean because one host is isolated.

C. Billing is paused; restoration still requires the specified response and service-owner process.

D. Restore immediately because isolation proves the cause is removed.

3. A colleague needs the term for this meaning: Removal of incident causes or persistence as applicable. Which term fits?

A. lateral movement

B. eradication

C. decision authority

D. action log

D Choose the response that fits / continued

4. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "I put nine eighteen as the isolation time in my update. That was only permission to act. I will change it to nine twenty-two." Mara: [missing response] Joel: "Would restarting B7 help us resume sooner? Someone suggested it in the operations channel, but I do not know what investigators still need." Which response belongs in the gap?

A. Route that request through the response team. Evidence preservation is in progress, and an improvised state change could affect the investigation. We must coordinate recovery and evidence needs.

B. Keep the incident scope open in the update. One known host does not prove that there are no others, but uncertainty is not evidence that all systems are affected.

C. Please also keep the business impact concrete: billing jobs are paused. We have not established that every related service is affected or that customer data left the environment.

D. That is accurate. Recovery remains subject to the required checks and joint decision. We will give the next factual update at nine forty-five even if uncertainty remains.

Answers and explanations, page 123

> **One useful distinction**
>
> 09:18 is the authorization time; 09:22 is verified completion. Saying isolated at 09:18 would merge two different events. Record both so later reviewers can reconstruct what actually happened.

E Conversation

Isolation is complete; the investigation is not

Isolation is complete; the investigation is not

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

incident scope / containment / business impact / Eradication / decision authority / Evidence preservation / status update / handover / action log / Recovery

01 **Joel:** Billing is paused, and the team wants a restoration time. We know B7 is isolated. Can I tell them the incident is now over?

02 **Mara:** No. The [1] _____ action is complete, but cause, data access, and wider scope remain unconfirmed. We should be precise about what that completed action means.

03 **Joel:** Give me the timeline so I can explain the interruption. I have nine ten in the report and nine eighteen in the response channel.

04 **Mara:** The [2] _____ should show first report at nine ten, isolation authorization at nine eighteen, and verified completion at nine twenty-two, all UTC.

05 **Joel:** I put nine eighteen as the isolation time in my update. That was only permission to act. I will change it to nine twenty-two.

06 **Mara:** Please also keep the [3] _____ concrete: billing jobs are paused. We have not established that every related service is affected or that customer data left the environment.

E Conversation / continued

07 **Joel:** Would restarting B7 help us resume sooner? Someone suggested it in the operations channel, but I do not know what investigators still need.

08 **Mara:** Route that request through the response team. [4] _____ is in progress, and an improvised state change could affect the investigation. We must coordinate recovery and evidence needs.

09 **Joel:** I will stop treating restart as a routine operations decision here. Who needs to agree before this service can return under our process?

10 **Mara:** The [5] _____ includes the response lead and you as service owner. Technical checks and operational consequences need to be assessed together before restoration.

Conversation continues on the next page.

Isolation is complete; the investigation is not

CONVERSATION / CONTINUED

11 **Joel:** I can explain the business impact and available operational options. I cannot certify from isolation alone that the underlying problem has been removed.

12 **Mara:** Correct. [6] _____ has not been confirmed. We also cannot infer the absence of earlier unauthorized data access from the fact that connections are restricted now.

13 **Joel:** The team has also asked whether other hosts are involved. I only have the report about B7, so I have not named additional systems.

14 **Mara:** Keep the [7] _____ open in the update. One known host does not prove that there are no others, but uncertainty is not evidence that all systems are affected.

15 **Joel:** What can I promise for nine forty-five: an update, or a working service? People will read the time as a restoration deadline unless I spell it out.

16 **Mara:** An update, not a working service. The [8] _____ is at nine forty-five. We'll report what changed, what remains unresolved, and the next actions. That time isn't a restoration estimate.

17 **Joel:** I will say that plainly. I also need the next shift to understand what was authorized and which checks are still open when they arrive.

18 **Mara:** Use the [9] _____ record, including timestamps, owners, and outstanding decisions. They should not have to infer permission from a short chat message or an optimistic headline.

19 **Joel:** My message will say B7 is isolated, billing jobs remain paused, and investigation continues. I will reserve any all-clear for the authorized process.

20 **Mara:** That is accurate. [10] _____ remains subject to the required checks and joint decision. We will give the next factual update at nine forty-five even if uncertainty remains.

CHECK THE GAPS

1. containment / **2.** action log / **3.** business impact / **4.** Evidence preservation / **5.** decision authority / **6.** Eradication / **7.** incident scope / **8.** status update / **9.** handover / **10.** Recovery

Why these answers fit, page 124

F Check accuracy and scope

Isolation is complete; the investigation is not

Return to the case

Incident coordinator Mara briefs service owner Joel about suspected unauthorized activity on billing host B7, first reported at 09:10 UTC. Under the approved playbook, Mara authorized network isolation at 09:18; completion was verified at 09:22. Billing jobs are paused. Investigators are preserving available evidence; cause, data access, and wider scope remain unconfirmed. Restoration requires the response lead and service owner under the local process. The next update is due at 09:45, not a promised restoration time.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. Which statement about data access is justified?

A. Unauthorized data access has not been confirmed.
B. No data was accessed under any circumstances.
C. All billing data was exfiltrated.
D. Isolation proves that no earlier transfer occurred.

2. What belongs in the handover?

A. An undocumented restoration promise
B. Actions, timestamps, impact, open questions, and responsible roles
C. Only a reassuring headline
D. A root cause selected to end uncertainty

Answers and explanations, page 126

Listen for the distinction

Switch roles for turns 11-20. Stress that the next update is not a recovery promise.

Be decisive about the action, exact about the result

During a response, colleagues need short updates that they can repeat accurately. Separate the completed action from what it has not established. A calm statement of uncertainty is more useful than either dramatic speculation or premature reassurance.

F Say it / transfer to a new case

A report time is not a recovery deadline

Host C4 was first reported at 11:00 UTC. Isolation was authorized at 11:05 and verified complete at 11:09. The next update is 11:30. Recovery has not been authorized.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

11:05 / 11:30 / unauthorized / 11:09

01 **Coordinator:** Isolation was authorized at [1] _____ UTC.

02 **Owner:** Completion was verified at [2] _____ UTC.

03 **Coordinator:** Our next update is at [3] _____ UTC.

04 **Owner:** Recovery remains [4] _____.

CHECK THE GAPS

1. 11:05 / **2.** 11:09 / **3.** 11:30 / **4.** unauthorized

Why these answers fit, page 126

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "The team has also asked whether other hosts are involved. I only have the report about B7, so I have not named additional systems." Mara: [missing response] Joel: "What can I promise for nine forty-five: an update, or a working service? People will read the time as a restoration deadline unless I spell it out." Which response belongs in the gap?

A. Route that request through the response team. Evidence preservation is in progress, and an improvised state change could affect the investigation. We must coordinate recovery and evidence needs.

B. Keep the incident scope open in the update. One known host does not prove that there are no others, but uncertainty is not evidence that all systems are affected.

C. An update, not a working service. The status update is at nine forty-five. We'll report what changed, what remains unresolved, and the next actions. That time isn't a restoration estimate.

D. Please also keep the business impact concrete: billing jobs are paused. We have not established that every related service is affected or that customer data left the environment.

Answers and explanations, page 127

Review 1 / Meaning and context

Use language from the lessons you have completed. Choose one answer per question.

> **Case file**
>
> Revisit "Security Triage and Alert Investigation" and "Incident Response and Containment". Choose precise terminology, then reconstruct the missing responses using both neighboring turns. The final two questions also revisit earlier conversations.

1. A colleague needs the term for this meaning: An occurrence assessed as compromising or threatening security. Which term fits?

A. incident
B. log source
C. authorization
D. benign activity

2. A colleague needs the term for this meaning: Agreed guidance for handling a defined situation. Which term fits?

A. playbook
B. affected host
C. incident response
D. business impact

3. Rebuild the exchange from "A successful login is not verified authorization". Anika: "The dashboard says new address. Is that enough to label the source hostile, or should I just report that it is unfamiliar?" Luis: [missing response] Anika: "Understood. I will say that the identity log records success, the source is unfamiliar, and the account holder has not confirmed the activity." Which response belongs in the gap?

A. Start with the event, then tell me what remains unknown. A successful sign-in matters, but I do not want the handoff to imply confirmed hostile activity.
B. Call it an anomaly. It deserves investigation, but novelty does not establish who controlled the connection. The maintenance explanation still needs testing, just as the hostile explanation does.
C. Record the visibility gap explicitly. We cannot use an incomplete application search to say that nothing happened after the sign-in, even if the records we have look ordinary.
D. Keep triage moving. Our process requires escalation now, and your uncertainty belongs in the update. We can investigate without accusing the owner or announcing a confirmed intrusion.

Review 1 / Meaning and context / continued

4. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "I will say that plainly. I also need the next shift to understand what was authorized and which checks are still open when they arrive." Mara: [missing response] Joel: "My message will say B7 is isolated, billing jobs remain paused, and investigation continues. I will reserve any all-clear for the authorized process." Which response belongs in the gap?

A. No. The containment action is complete, but cause, data access, and wider scope remain unconfirmed. We should be precise about what that completed action means.

B. That is accurate. Recovery remains subject to the required checks and joint decision. We will give the next factual update at nine forty-five even if uncertainty remains.

C. Correct. Eradication has not been confirmed. We also cannot infer the absence of earlier unauthorized data access from the fact that connections are restricted now.

D. Use the handover record, including timestamps, owners, and outstanding decisions. They should not have to infer permission from a short chat message or an optimistic headline.

Answers and explanations, page 158

A Read the situation

LESSON 03 / VULNERABILITY MANAGEMENT

Explain a risk-based remediation order without treating severity scores as complete business-risk assessments.

> **The same score, a different repair priority**
>
> Vulnerability analyst Chen and infrastructure owner Petra review two fictional findings, each with a base severity score of 8.8. A affects an internet-facing production gateway; a validated threat bulletin reports exploitation of that flaw elsewhere. B affects an isolated test server containing synthetic data, with no route from the internet. No local exploitation is confirmed. Their agreed rule prioritizes demonstrated exploitation and external exposure when scores tie. A patch is available for each; testing, change approval, and verification remain required.

People: Chen, Vulnerability analyst; Petra, Infrastructure owner.

Read the record

Choose one answer per question using the facts above.

1. Which finding comes first under the stated tie-break rule?

A. A, the exposed production gateway flaw
B. B, because test systems always come first
C. Both must have identical handling because scores match
D. Neither, because local exploitation is unconfirmed

2. What does the threat bulletin establish?

A. This organization is definitely compromised.
B. The patch has passed local tests.
C. B is reachable from the internet.
D. The flaw has been exploited elsewhere.

3. What remains required after selecting A first?

A. Closing both findings immediately
B. Testing, change approval, and verification
C. Only updating the priority label
D. Assuming the available patch is already installed

Answers and explanations, page 128

B Vocabulary in use

CORE TERMS

vulnerability
A weakness that can be exploited to harm security.

assess a vulnerability

CVE
Common Vulnerabilities and Exposures, an identification system.

reference a CVE identifier

CVSS
Common Vulnerability Scoring System, a severity framework.

interpret a CVSS score

base score
A severity score based on intrinsic vulnerability characteristics.

compare base scores

exploit
A means of taking advantage of a vulnerability.

assess exploit availability

exploitation in the wild
Observed real-world use of a vulnerability.

confirm exploitation in the wild

KEV catalog
CISA's list of vulnerabilities known to have been exploited.

check the KEV catalog

internet-facing
Reachable through an internet-exposed service or interface.

inventory internet-facing assets

asset criticality
The importance of an asset to organizational objectives.

assess asset criticality

attack surface
The exposed points through which a system can be targeted.

reduce the attack surface

reachability
Whether a relevant path to an asset or service exists.

verify reachability

affected version
A software version within a vulnerability's stated scope.

confirm the affected version

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

vulnerability VULNERABILITY

assess a vulnerability

Keep the meaning precise: A weakness that can be exploited to harm security.

exploitation in the wild EXPLOITATION IN THE WILD

confirm exploitation in the wild

Keep the meaning precise: Observed real-world use of a vulnerability.

B Precision and professional shorthand

EXTEND YOUR RANGE

patch
A software update intended to correct a defect.

validate a patch

mitigation
A measure intended to reduce exposure or impact.

verify a mitigation

remediation window
An agreed period for completing corrective work.

agree a remediation window

regression test
A check that a change has not broken existing behavior.

run regression tests

false finding
A reported weakness not supported after validation.

investigate a false finding

risk acceptance
An authorized decision to retain a specified risk.

document risk acceptance

remediation
Work to resolve an identified weakness or problem.

prioritize remediation

compensating control
An alternative safeguard addressing a defined control need.

evaluate a compensating control

change approval
Permission to carry out a defined system change.

obtain change approval

rescan
A follow-up scan to reassess a finding.

perform a rescan

exception expiry
The date or condition ending an approved exception.

track exception expiry

closure evidence
Records showing that the required completion conditions were met.

attach closure evidence

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

affected version AFFECTED VERSION

confirm the affected version

Keep the meaning precise: A software version within a vulnerability's stated scope.

remediation window REMEDIATION WINDOW

agree a remediation window

Keep the meaning precise: An agreed period for completing corrective work.

C Phrases that move the work forward

Acknowledge the tie
"Both findings have a base score of 8.8."

Name the exposure
"That service is internet-facing."

Preserve local uncertainty
"We have not confirmed local exploitation."

Keep B visible
"B remains in the remediation queue."

Keep change controls
"Priority does not replace testing or approval."

Specify verification
"Attach evidence that the affected condition is resolved."

Bound a mitigation
"State which exposure the temporary control reduces."

Clarify the decision
"We are selecting the work order, not declaring an incident."

Add the asset context
"A affects the production gateway."

Qualify the threat evidence
"The bulletin confirms exploitation elsewhere."

Apply the agreed rule
"Our tie-break rule prioritizes A."

Distinguish availability
"The patch is available, not yet deployed."

Ask about service impact
"What interruption does the approved change require?"

Avoid an unsupported closure
"An installation message alone does not close the finding."

Name the exception owner
"Any delay needs the required owner and expiry."

Close with a handoff
"Record A first, B still open, and the remaining change steps."

Precision in real exchanges

Purpose: Qualify the threat evidence
Useful wording: "The bulletin confirms exploitation elsewhere."

Purpose: Preserve local uncertainty
Useful wording: "We have not confirmed local exploitation."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which explanation is strongest for A first?

A. Equal scores; A adds external exposure and validated exploitation evidence under the agreed rule.

B. A has a higher supplied score.

C. B has no possible risk under any circumstances.

D. A is already proven to be compromised locally.

2. Which statement about B is accurate?

A. It is permanently exempt because it uses synthetic data.

B. Its score must be changed to zero.

C. It is internet-facing because A is.

D. It is lower in this ordering but still requires handling.

3. A colleague needs the term for this meaning: A severity score based on intrinsic vulnerability characteristics. Which term fits?

A. mitigation

B. base score

C. false finding

D. asset criticality

D Choose the response that fits / continued

4. Rebuild the exchange from "The same score, a different repair priority". Petra: "The bulletin says the gateway flaw has been used against other organizations. Does that mean we should announce an incident in our own environment?" Chen: [missing response] Petra: "Fine, A first. Can we leave B assigned and visible? I do not want lower priority to turn into nobody owning the test-server fix." Which response belongs in the gap?

A. No. It establishes exploitation in the wild, not local compromise. We should preserve that distinction while using the verified information as a reason to prioritize corrective work.

B. Attach the closure evidence to the record. The person reviewing completion should see why the affected condition is considered resolved, not just that someone ran an installer.

C. The base score is the same, but our tie-break rule uses exposure and demonstrated exploitation. A has both of those additional facts in the assessment we have.

D. Keep it in the remediation queue. The ordering is A first under our agreed rule, not A matters and B never matters. Both need an accountable path.

Answers and explanations, page 128

> **One useful distinction**
>
> A base severity score describes vulnerability characteristics, not the complete risk to a particular organization. Exposure, affected assets, observed exploitation, and local controls can justify different priorities for equal scores.

E Conversation

The same score, a different repair priority

The same score, a different repair priority

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

base score / regression test / asset criticality / remediation / internet-facing / closure evidence / risk acceptance / change approval / mitigation / exploitation in the wild

01 **Petra:** Both findings are eight point eight. The operations queue usually sorts by score, so I need a clear reason to move the gateway ahead.

02 **Chen:** The [1] _____ is the same, but our tie-break rule uses exposure and demonstrated exploitation. A has both of those additional facts in the assessment we have.

03 **Petra:** Let us separate those facts. A is the production gateway reachable externally. B is an isolated test server holding synthetic rather than live customer data.

04 **Chen:** Yes. A is [2] _____, while B has no route from the internet in this case. That changes the immediate exposure even before we discuss the bulletin.

05 **Petra:** The bulletin says the gateway flaw has been used against other organizations. Does that mean we should announce an incident in our own environment?

06 **Chen:** No. It establishes [3] _____, not local compromise. We should preserve that distinction while using the verified information as a reason to prioritize corrective work.

07 **Petra:** Fine, A first. Can we leave B assigned and visible? I do not want lower priority to turn into nobody owning the test-server fix.

08 **Chen:** Keep it in the [4] _____ queue. The ordering is A first under our agreed rule, not A matters and B never matters. Both need an accountable path.

09 **Petra:** A patch is available for each. The gateway update may interrupt production, so we still need the service team involved in timing and checks.

10 **Chen:** Obtain the required [5] _____. Prioritizing A does not prove the update is compatible or authorize an unplanned production interruption. We need the relevant testing and operational coordination.

Conversation continues on the next page.

The same score, a different repair priority

CONVERSATION / CONTINUED

11 **Petra:** Then my ticket will say selected first, patch available, testing and approval pending. I will not mark it resolved just because we found an update.

12 **Chen:** Good. The [6] _____ should cover the relevant existing service behavior. A security correction still needs evidence that the planned change works in the required environment.

13 **Petra:** If we cannot deploy immediately, the service owner may propose a temporary control. I want the wording to make clear what that would actually achieve.

14 **Chen:** Describe it as a [7] _____ with a defined scope and verification. Do not claim that reducing one access path automatically corrects the underlying software or removes every route.

15 **Petra:** Any delay would need the owner, rationale, and review conditions required by our process. An informal note saying accepted would be too vague.

16 **Chen:** Exactly. Formal [8] _____ is not something the analyst can invent to clear the queue. It must follow the assigned authority and state what remains exposed.

17 **Petra:** After installation, what evidence do you need to close the finding? I can attach the change record, but we still need to verify the affected condition.

18 **Chen:** Attach the [9] _____ to the record. The person reviewing completion should see why the affected condition is considered resolved, not just that someone ran an installer.

19 **Petra:** My summary is A first for demonstrated exploitation and external exposure, B still open, and no local exploitation confirmed. The change steps remain required.

20 **Chen:** That makes the [10] _____ and exposure visible alongside severity. We can justify urgency without exaggerating the evidence or treating the score as the whole decision.

CHECK THE GAPS

1. base score / **2.** internet-facing / **3.** exploitation in the wild / **4.** remediation / **5.** change approval / **6.** regression test / **7.** mitigation / **8.** risk acceptance / **9.** closure evidence / **10.** asset criticality

Why these answers fit, page 129

F Check accuracy and scope

The same score, a different repair priority

Return to the case

Vulnerability analyst Chen and infrastructure owner Petra review two fictional findings, each with a base severity score of 8.8. A affects an internet-facing production gateway; a validated threat bulletin reports exploitation of that flaw elsewhere. B affects an isolated test server containing synthetic data, with no route from the internet. No local exploitation is confirmed. Their agreed rule prioritizes demonstrated exploitation and external exposure when scores tie. A patch is available for each; testing, change approval, and verification remain required.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. What distinguishes a patch from a mitigation?

A. A patch changes software; another control may reduce exposure without correcting that software.

B. Every mitigation installs a patch.

C. A patch is only a risk-acceptance signature.

D. A mitigation proves all vulnerabilities are absent.

2. Which closure message is supported before any deployment?

A. The threat bulletin certifies local recovery.

B. A is prioritized; deployment and verification are still pending.

C. A is resolved because a patch exists.

D. Both findings are closed because a plan exists.

Answers and explanations, page 131

Listen for the distinction

Switch roles for turns 11-20. Keep available, deployed, and verified distinct.

Explain the ranking, not just the number

Operations teams need a reason to interrupt planned work. Connect the weakness to the affected asset, exposure, and exploitation evidence. A defensible priority is more persuasive than repeating a severity label while ignoring operational change controls.

F Say it / transfer to a new case

A high priority is not completed work

Findings X and Y have equal base scores. X is internet-facing with verified exploitation elsewhere; Y is isolated. The local rule selects X first. Its patch is available, but deployment has not started.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

pending / elsewhere / X / equal

01 **Analyst:** The first priority is [1] _____.

02 **Owner:** The base scores are [2] _____.

03 **Analyst:** Exploitation is verified [3] _____.

04 **Owner:** Deployment is still [4] _____.

CHECK THE GAPS

1. X / **2.** equal / **3.** elsewhere / **4.** pending

Why these answers fit, page 131

F Say it / transfer to a new case / continued

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "The same score, a different repair priority". Petra: "If we cannot deploy immediately, the service owner may propose a temporary control. I want the wording to make clear what that would actually achieve." Chen: [missing response] Petra: "Any delay would need the owner, rationale, and review conditions required by our process. An informal note saying accepted would be too vague." Which response belongs in the gap?

A. The base score is the same, but our tie-break rule uses exposure and demonstrated exploitation. A has both of those additional facts in the assessment we have.

B. Obtain the required change approval. Prioritizing A does not prove the update is compatible or authorize an unplanned production interruption. We need the relevant testing and operational coordination.

C. Describe it as a mitigation with a defined scope and verification. Do not claim that reducing one access path automatically corrects the underlying software or removes every route.

D. No. It establishes exploitation in the wild, not local compromise. We should preserve that distinction while using the verified information as a reason to prioritize corrective work.

Answers and explanations, page 132

A Read the situation

LESSON 04 / IDENTITY, ACCESS, AND LEAST PRIVILEGE

Negotiate a specific access arrangement using identity, task, permission, duration, approval, and accountability.

> **Support needs logs, not a shared administrator**
>
> Vendor coordinator Eva requests a shared administrator account so two technicians can diagnose a service issue. Access reviewer Rashid confirms that the supplied task needs only read access to sanitized diagnostic logs for two hours. Their local policy requires named identities, multifactor authentication, owner approval, and recorded expiry. No approval has been granted. The proposed alternative gives each technician only the required log access. Any later write task needs a separate assessed request; no broader privilege is justified by the present facts.

People: Eva, Vendor coordinator; Rashid, Access reviewer.

Read the record

Choose one answer per question using the facts above.

1. What does the diagnostic task require?

A. Read access to sanitized logs for two hours
B. Permanent administrator access
C. A shared password for all staff
D. Unrestricted production write access

2. Which local requirement is explicit?

A. Named identities with multifactor authentication, approval, and expiry
B. Anonymous access if the vendor is familiar
C. No review for short tasks
D. Automatic approval after a request

3. What is the current approval status?

A. Not granted
B. Granted by the request alone
C. Unnecessary because the logs are sanitized
D. Permanent approval for future tasks

Answers and explanations, page 133

B Vocabulary in use

CORE TERMS

identity and access management
Processes for managing identities and their permissions.

review identity and access management

named account
An account associated with an identified individual.

provision a named account

privileged access
Permission to perform elevated system actions.

control privileged access

entitlement
A specific right or permission assigned to an identity.

review entitlements

multifactor authentication
Verification using more than one distinct factor type.

require multifactor authentication

federation
Trust between identity systems to support identity assertions.

configure identity federation

least privilege
Limiting access to what the authorized task requires.

apply least privilege

shared account
An account used by more than one individual.

review shared-account risk

read-only access
Permission to view data without changing it.

grant read-only access

role-based access
Permissions assigned through defined job or task roles.

configure role-based access

single sign-on
Access to multiple services through a shared sign-in arrangement.

support single sign-on

provisioning
Creating or enabling an identity or its access.

complete access provisioning

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

identity and access management IDENTITY AND ACCESS MANAGEMENT

review identity and access management

Keep the meaning precise: Processes for managing identities and their permissions.

read-only access READ-ONLY ACCESS

grant read-only access

Keep the meaning precise: Permission to view data without changing it.

B Precision and professional shorthand

EXTEND YOUR RANGE

deprovisioning

Removing or disabling access that is no longer needed.

verify deprovisioning

time-bound access

Permission with a defined end time or duration.

approve time-bound access

just-in-time access

Access activated only for an approved period of need.

request just-in-time access

session record

Information documenting a particular access session.

review session records

separation of duties

Dividing sensitive responsibilities to reduce conflicting control.

maintain separation of duties

service account

An identity used by a service or automated process.

manage service-account permissions

access review

Evaluation of whether granted rights remain appropriate.

conduct an access review

expiry

The point at which a permission or approval ends.

record access expiry

standing privilege

Elevated access retained beyond a particular active task.

reduce standing privilege

accountability

Ability to associate actions with responsible identities.

preserve individual accountability

break-glass access

Controlled emergency access outside the normal route.

govern break-glass access

sanitized logs

Diagnostic records with restricted details removed or protected.

share sanitized logs

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

provisioning PROVISIONING

complete access provisioning

Keep the meaning precise: Creating or enabling an identity or its access.

just-in-time access JUST-IN-TIME ACCESS

request just-in-time access

Keep the meaning precise: Access activated only for an approved period of need.

C Phrases that move the work forward

Acknowledge the support need
"We need to enable the diagnostic work."

Use the supplied scope
"The task only needs sanitized diagnostic logs."

Preserve identity
"Each technician needs a named account."

Bound the duration
"The requested access lasts two hours."

Protect accountability
"We need to associate actions with each technician."

Name expiry
"Record when the access ends."

Avoid a personal judgment
"The restriction follows the task, not a judgment about the vendor."

Confirm removal
"Verify that access ends as approved."

Clarify the task
"Which action requires administrator rights?"

Offer narrower access
"Read-only access supports that task."

State the local condition
"Multifactor authentication is required."

Keep approval explicit
"The service owner has not approved it yet."

Avoid standing access
"This request does not justify permanent privilege."

Separate future work
"A later write task needs a new assessed request."

Ask for evidence
"Please include the task, identities, and duration."

Close the proposal
"Submit named, read-only, time-bound access for owner review."

Precision in real exchanges

Purpose: Offer narrower access
Useful wording: "Read-only access supports that task."

Purpose: Preserve identity
Useful wording: "Each technician needs a named account."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which proposal best matches the supplied task and policy?

A. Named read-only log access for two hours, with MFA and owner approval
B. Shared read-only log access for two hours, with MFA and owner approval
C. Named administrator access for two hours, with MFA and owner approval
D. Named read-only log access with MFA and owner approval, without an expiry

2. Why does MFA not settle the request?

A. It strengthens identity verification but does not justify unnecessary permissions.
B. It guarantees every requested action is appropriate.
C. It replaces the need for named identities in this policy.
D. It means the account can never be misused.

3. A colleague needs the term for this meaning: An account used by more than one individual. Which term fits?

A. multifactor authentication
B. shared account
C. separation of duties
D. time-bound access

D Choose the response that fits / continued

4. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "They will take turns during the two hours. Can one account cover both, or do we need two identities even for that short window?" Rashid: [missing response] Eva: "I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?" Which response belongs in the gap?

A. Our policy requires a named account for each technician. A private agreement about sharing does not replace individual attribution or the access conditions we have been asked to enforce.

B. That is a new entitlement question. Do not silently add write access to a request justified only by log reading. The additional need must go through its own assessment.

C. We require multifactor authentication. We need to verify that the approved arrangement meets it, not rely on the general adjective secure or treat vendor familiarity as an exemption.

D. Let us start with least privilege. The supplied task needs read access to sanitized diagnostic logs for two hours. Which part requires changing the system or administering it?

Answers and explanations, page 133

> **One useful distinction**
>
> Authentication checks identity; authorization controls permitted actions. Multifactor authentication does not by itself justify administrator rights. Sanitization also does not remove the stated approval, identity, and expiry requirements.

E Conversation

Support needs logs, not a shared administrator

Support needs logs, not a shared administrator

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

multifactor authentication / Accountability / entitlement / named account / deprovisioning / Provisioning / read-only access / expiry / time-bound access / least privilege

01 **Eva:** Two vendor technicians need to investigate the service issue. They asked for a shared administrator account so either person can begin when available.

02 **Rashid:** Let us start with [1] _____. The supplied task needs read access to sanitized diagnostic logs for two hours. Which part requires changing the system or administering it?

03 **Eva:** None of the documented diagnostic steps requires a write. They want to inspect the logs and compare the recorded errors with their product knowledge.

04 **Rashid:** Then propose [2] _____. That supports the described work without granting unrelated administrative rights. We should make the permitted action clear in the request.

05 **Eva:** They will take turns during the two hours. Can one account cover both, or do we need two identities even for that short window?

06 **Rashid:** Our policy requires a [3] _____ for each technician. A private agreement about sharing does not replace individual attribution or the access conditions we have been asked to enforce.

E Conversation / continued

07 **Eva:** I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?

08 **Rashid:** We require [4] _____. We need to verify that the approved arrangement meets it, not rely on the general adjective secure or treat vendor familiarity as an exemption.

09 **Eva:** That gives me the identity and sign-in requirements. For timing, I can specify a two-hour window rather than leaving the access available indefinitely.

10 **Rashid:** Make it [5] _____ with a recorded end. Short work does not justify standing privilege, and the duration should be visible to whoever reviews and implements the request.

Conversation continues on the next page.

Support needs logs, not a shared administrator

CONVERSATION / CONTINUED

11 **Eva:** I have submitted the request, but the owner has not signed off. What can I tell the technicians while that decision is pending?

12 **Rashid:** Correct. [6] _____ follows the required approval. A well-scoped request is ready for review; it does not authorize itself simply because the proposed permissions are narrow.

13 **Eva:** If their diagnosis later shows that a configuration change is needed, I will ask them to describe the new action and why it is necessary.

14 **Rashid:** That is a new [7] _____ question. Do not silently add write access to a request justified only by log reading. The additional need must go through its own assessment.

15 **Eva:** I can explain that this is about fitting access to work, not suggesting that the technicians intend to misuse anything. We still want their support.

16 **Rashid:** Exactly. [8] _____ also protects legitimate work by showing who did what. Neutral language makes that purpose clearer than a blanket statement that vendors are risky.

17 **Eva:** I will put the identities, read-only log scope, multifactor requirement, two-hour duration, and owner decision in the request. What should I say about the end?

18 **Rashid:** Record the [9] _____ and confirm how it will be enforced. The access should not remain active simply because everyone assumes somebody else will remove it later.

Support needs logs, not a shared administrator / continued

19 **Eva:** Then I will send the bounded proposal for owner review and avoid promising administrator access. Any changed task will return with a specific justification.

20 **Rashid:** Good. Verify [10] _____ when the approved window ends. We can enable the diagnostic work while keeping permission, duration, approval, and individual responsibility explicit.

CHECK THE GAPS

1. least privilege / **2.** read-only access / **3.** named account / **4.** multifactor authentication / **5.** time-bound access / **6.** Provisioning / **7.** entitlement / **8.** Accountability / **9.** expiry / **10.** deprovisioning

Why these answers fit, page 134

F Check accuracy and scope

Support needs logs, not a shared administrator

Return to the case

Vendor coordinator Eva requests a shared administrator account so two technicians can diagnose a service issue. Access reviewer Rashid confirms that the supplied task needs only read access to sanitized diagnostic logs for two hours. Their local policy requires named identities, multifactor authentication, owner approval, and recorded expiry. No approval has been granted. The proposed alternative gives each technician only the required log access. Any later write task needs a separate assessed request; no broader privilege is justified by the present facts.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. What should happen if a write task emerges?

A. Submit the additional need for a separate assessment.
B. Quietly add write access to the original request.
C. Treat all future tasks as already approved.
D. Reuse a shared administrator password without a record.

2. Which explanation avoids blaming the vendor?

A. The task requires log reading, so we are proposing only that access.
B. Vendors always misuse administrator accounts.
C. Familiar technicians never need access review.
D. We are refusing all support without reviewing the task.

Answers and explanations, page 136

Listen for the distinction

Switch roles for turns 11-20. Stress pending approval and the recorded expiry.

Offer a workable boundary

A useful access challenge connects the restriction to the task and offers a precise alternative. Avoid sounding as though vendor status itself makes someone untrustworthy. Explain which requested permissions are unnecessary and how the legitimate work can proceed through the approved route.

F Say it / transfer to a new case

The task sets the boundary

A technician needs to view sanitized logs for three hours. Local policy requires a named identity, MFA, owner approval, and expiry. Approval is still pending; no write task is supplied.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

named / three / pending / read-only

01 **Coordinator:** The requested permission is [1] _____.

02 **Reviewer:** The requested duration is [2] _____ hours.

03 **Coordinator:** The identity must be [3] _____.

04 **Reviewer:** Owner approval remains [4] _____.

CHECK THE GAPS

1. read-only / **2.** three / **3.** named / **4.** pending

Why these answers fit, page 136

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "If their diagnosis later shows that a configuration change is needed, I will ask them to describe the new action and why it is necessary." Rashid: [missing response] Eva: "I can explain that this is about fitting access to work, not suggesting that the technicians intend to misuse anything. We still want their support." Which response belongs in the gap?

A. Our policy requires a named account for each technician. A private agreement about sharing does not replace individual attribution or the access conditions we have been asked to enforce.

B. That is a new entitlement question. Do not silently add write access to a request justified only by log reading. The additional need must go through its own assessment.

C. We require multifactor authentication. We need to verify that the approved arrangement meets it, not rely on the general adjective secure or treat vendor familiarity as an exemption.

D. Let us start with least privilege. The supplied task needs read access to sanitized diagnostic logs for two hours. Which part requires changing the system or administering it?

Answers and explanations, page 137

Review 2 / Meaning and context

Use language from the lessons you have completed. Choose one answer per question.

> **Case file**
>
> Revisit "Vulnerability Management" and "Identity, Access, and Least Privilege". Choose precise terminology, then reconstruct the missing responses using both neighboring turns. The final two questions also revisit earlier conversations.

1. A colleague needs the term for this meaning: Common Vulnerability Scoring System, a severity framework. Which term fits?

A. CVSS

B. remediation

C. rescan

D. internet-facing

2. A colleague needs the term for this meaning: Permissions assigned through defined job or task roles. Which term fits?

A. role-based access

B. identity and access management

C. session record

D. deprovisioning

3. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "I will stop treating restart as a routine operations decision here. Who needs to agree before this service can return under our process?" Mara: [missing response] Joel: "I can explain the business impact and available operational options. I cannot certify from isolation alone that the underlying problem has been removed." Which response belongs in the gap?

A. The decision authority includes the response lead and you as service owner. Technical checks and operational consequences need to be assessed together before restoration.

B. Correct. Eradication has not been confirmed. We also cannot infer the absence of earlier unauthorized data access from the fact that connections are restricted now.

C. The action log should show first report at nine ten, isolation authorization at nine eighteen, and verified completion at nine twenty-two, all UTC.

D. No. The containment action is complete, but cause, data access, and wider scope remain unconfirmed. We should be precise about what that completed action means.

Review 2 / Meaning and context / continued

4. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "I will put the identities, read-only log scope, multifactor requirement, two-hour duration, and owner decision in the request. What should I say about the end?" Rashid: [missing response] Eva: "Then I will send the bounded proposal for owner review and avoid promising administrator access. Any changed task will return with a specific justification." Which response belongs in the gap?

A. Exactly. Accountability also protects legitimate work by showing who did what. Neutral language makes that purpose clearer than a blanket statement that vendors are risky.

B. Record the expiry and confirm how it will be enforced. The access should not remain active simply because everyone assumes somebody else will remove it later.

C. Let us start with least privilege. The supplied task needs read access to sanitized diagnostic logs for two hours. Which part requires changing the system or administering it?

D. Correct. Provisioning follows the required approval. A well-scoped request is ready for review; it does not authorize itself simply because the proposed permissions are narrow.

Answers and explanations, page 161

A Read the situation

LESSON 05 / THREAT MODELING AND SECURE DESIGN

Trace a data flow, identify a trust boundary, and turn a specific abuse case into a testable design requirement.

A sign-in check does not decide document access

Architect Noor and security engineer Daniel review a fictional document portal. A signed-in browser sends a document ID to a service, which retrieves a file from storage. The draft checks the user at sign-in but does not specify a server-side check that the user may access the requested document. Customers must see only their own organization-owned documents. The review has no implemented-system test result or confirmed breach. Daniel proposes a per-request authorization check and an approved test using separate fictional tenant accounts.

People: Noor, Application architect; Daniel, Security engineer.

Read the record

Choose one answer per question using the facts above.

1. What does the supplied draft already check?

A. Authorization for every requested document
B. That every customer owns every file
C. The outcome of an implemented-system test
D. The user at sign-in

2. What security requirement is supplied?

A. Every signed-in user may read every document.
B. Storage may trust every browser-supplied identifier.
C. A document ID grants access by itself.
D. Customers may see only their own organization-owned documents.

3. What is not established?

A. A confirmed breach or implemented-system test result
B. The existence of browser requests
C. The use of document identifiers
D. The need to restrict documents by organization

Answers and explanations, page 138

B Vocabulary in use

CORE TERMS

threat model
A structured account of relevant threats and responses.

review the threat model

data flow
Movement of information between system elements.

trace the data flow

trust boundary
A point where assumptions about control or trust change.

identify a trust boundary

external entity
An actor or system outside the modeled component.

identify external entities

process
A component that transforms or acts on data.

model the service process

data store
A location where information is retained.

identify data stores

asset
Something of value requiring protection.

identify sensitive assets

entry point
A place where data or interaction enters a system.

review entry points

abuse case
A scenario describing misuse of intended functionality.

define an abuse case

security requirement
A checkable condition protecting a security objective.

specify a security requirement

authentication check
A check of the claimed identity.

perform an authentication check

authorization check
A check of permission for a requested action.

enforce an authorization check

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

threat model THREAT MODEL

review the threat model

Keep the meaning precise: A structured account of relevant threats and responses.

data store DATA STORE

identify data stores

Keep the meaning precise: A location where information is retained.

B Precision and professional shorthand

EXTEND YOUR RANGE

object-level authorization

Permission enforcement for a specific requested object.

verify object-level authorization

tenant

A customer or organization sharing a service.

isolate tenant data

tenant isolation

Separation preventing unauthorized cross-tenant access.

test tenant isolation

server-side enforcement

A decision enforced by the service rather than the client.

require server-side enforcement

untrusted input

Data not accepted as authoritative without validation.

handle untrusted input

document identifier

A value used to refer to a specific document.

validate the document identifier

STRIDE

Spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege.

apply STRIDE categories

spoofing

Misrepresenting an identity or source.

assess spoofing threats

tampering

Unauthorized modification of data or system state.

prevent data tampering

information disclosure

Exposure of information to an unauthorized party.

prevent information disclosure

denial of service

Disruption of access to a service or resource.

assess denial-of-service risk

elevation of privilege

Gaining rights beyond the permitted level.

prevent elevation of privilege

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

authorization check AUTHORIZATION CHECK

enforce an authorization check

Keep the meaning precise: A check of permission for a requested action.

untrusted input UNTRUSTED INPUT

handle untrusted input

Keep the meaning precise: Data not accepted as authoritative without validation.

C Phrases that move the work forward

Start with the request
"The browser sends a document identifier to the service."

Trace the next step
"The service retrieves the file from storage."

Name the boundary
"The client-provided identifier crosses a trust boundary."

Acknowledge the existing check
"The draft checks identity at sign-in."

Identify the missing decision
"It does not specify permission for this document."

State the protected outcome
"Customers must see only their own organization's documents."

Keep the claim bounded
"We have a design gap, not a confirmed breach."

Make the abuse case concrete
"A signed-in user requests another tenant's document."

Place enforcement
"The permission check belongs on the server for each request."

Reject client trust
"A browser-supplied identifier is not authorization."

Define the denied case
"The service must deny access when the document is outside the user's permitted scope."

Preserve legitimate work
"The allowed same-tenant request must still work."

Use controlled testing
"Use approved test accounts and fictional documents."

Assign the requirement
"Add the access condition to the design and tests."

Separate categories
"This case concerns unauthorized disclosure of document content."

Close the review
"Record the requirement, its owner, and the validation evidence needed."

Precision in real exchanges

Purpose: Acknowledge the existing check
Useful wording: "The draft checks identity at sign-in."

Purpose: Identify the missing decision
Useful wording: "It does not specify permission for this document."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which requirement closes the identified design gap?

A. Enforce server-side permission for each requested document.
B. Require sign-in and then trust every document ID.
C. Hide the document ID in the page while omitting server checks.
D. Treat every authenticated user as a storage administrator.

2. Which pair best tests the stated boundary?

A. A search of live customer documents without approval
B. An authorized same-tenant request and a denied cross-tenant request using controlled data
C. Two requests by the same owner for the same file only
D. A page color check and a logo check

3. A colleague needs the term for this meaning: An actor or system outside the modeled component. Which term fits?

A. tenant isolation
B. abuse case
C. tampering
D. external entity

D Choose the response that fits / continued

4. Rebuild the exchange from "A sign-in check does not decide document access". Noor: "So the gap is not simply that somebody could be anonymous. It also concerns a legitimate user asking for a document outside their organization." Daniel: [missing response] Noor: "Could we just hide documents from other organizations in the browser? Or does the service need to enforce the same boundary independently?" Which response belongs in the gap?

A. Exactly. That is the abuse case we should record. It makes the missing decision concrete without claiming that the implemented system has already leaked anything or that a breach occurred.

B. The client crosses a trust boundary. A page convention does not give the server a dependable authorization decision. We need enforcement where the service controls access to the content.

C. Good. A useful security requirement is checkable and preserves intended use. We should identify the denied case and the allowed case instead of saying only make document access secure.

D. Keep the threat model precise: documented design gap, proposed requirement, validation pending. We should not manufacture certainty, but the lack of a live failure does not erase the gap.

Answers and explanations, page 138

One useful distinction

Identity and object permission are different decisions. A legitimate user may still request a document belonging to another organization. The design must specify where that permission is enforced, not merely that sign-in exists.

E Conversation

A sign-in check does not decide document access

A sign-in check does not decide document access

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

data flow / object-level authorization / server-side enforcement / abuse case / trust boundary / authorization check / security requirement / tenant isolation / information disclosure / threat model

01 **Noor:** The diagram lists the browser, service, and storage. We require sign-in before the document page, so I thought the main access question was covered.

02 **Daniel:** Let us trace the [1] _____. A browser sends a document identifier, the service processes it, and storage returns content. Where is permission for that particular document checked?

03 **Noor:** The draft does not say. It describes checking the user at sign-in, then retrieving the requested file. Our customers should see only their own organization's documents.

04 **Daniel:** That leaves an [2] _____ unspecified. We know who signed in, but we still need the service to decide whether that user may access the requested object.

05 **Noor:** So the gap is not simply that somebody could be anonymous. It also concerns a legitimate user asking for a document outside their organization.

06 **Daniel:** Exactly. That is the [3] _____ we should record. It makes the missing decision concrete without claiming that the implemented system has already leaked anything or that a breach occurred.

E Conversation / continued

07 **Noor:** Could we just hide documents from other organizations in the browser? Or does the service need to enforce the same boundary independently?

08 **Daniel:** The client crosses a [4] _____. A page convention does not give the server a dependable authorization decision. We need enforcement where the service controls access to the content.

09 **Noor:** Then the requirement should say the service checks permission on every request, using the authenticated user's allowed organization scope and the requested document.

10 **Daniel:** Yes, that is [5] _____. The service must deny access when the document is outside that permitted scope, while keeping the legitimate same-tenant request working.

Conversation continues on the next page.

A sign-in check does not decide document access

CONVERSATION / CONTINUED

11 **Noor:** I will put both outcomes into the design. Otherwise someone could call the issue fixed by denying every request and breaking the ordinary feature.

12 **Daniel:** Good. A useful [6] _____ is checkable and preserves intended use. We should identify the denied case and the allowed case instead of saying only make document access secure.

13 **Noor:** For validation, we can use two fictional organizations with controlled test accounts and documents in the approved environment. No live customer exploration is needed.

14 **Daniel:** That supports a [7] _____ check within an authorized scope. Record which account owns which document, the requested action, and the expected result before interpreting the observed outcome.

15 **Noor:** What label goes in the review: confirmed vulnerability or design gap? We have a draft in front of us, not an implementation test.

16 **Daniel:** Keep the [8] _____ precise: documented design gap, proposed requirement, validation pending. We should not manufacture certainty, but the lack of a live failure does not erase the gap.

17 **Noor:** I will assign the requirement to the service owner and include the browser input, storage ownership, and access-decision location in the revised diagram.

18 **Daniel:** Make [9] _____ explicit. The next reviewer should not have to guess whether the note describes a user-interface preference or an actual control over returned content.

A sign-in check does not decide document access / continued

19 **Noor:** The review record will distinguish the existing sign-in check, missing per-document rule, proposed controlled tests, and evidence still needed before we close the action.

20 **Daniel:** That is clear. The relevant harm here is [10] _____, and the response is a defined access decision. We have moved from a technology list to a reviewable requirement without overstating the evidence.

CHECK THE GAPS

1. data flow / **2.** authorization check / **3.** abuse case / **4.** trust boundary / **5.** object-level authorization / **6.** security requirement / **7.** tenant isolation / **8.** threat model / **9.** server-side enforcement / **10.** information disclosure

Why these answers fit, page 139

F Check accuracy and scope

A sign-in check does not decide document access

Return to the case

Architect Noor and security engineer Daniel review a fictional document portal. A signed-in browser sends a document ID to a service, which retrieves a file from storage. The draft checks the user at sign-in but does not specify a server-side check that the user may access the requested document. Customers must see only their own organization-owned documents. The review has no implemented-system test result or confirmed breach. Daniel proposes a per-request authorization check and an approved test using separate fictional tenant accounts.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. Which statement overclaims the review evidence?

A. A customer breach has definitely occurred.
B. The draft lacks a specified document-permission check.
C. A sign-in check is described.
D. The design needs a testable access condition.

2. Why is a browser-supplied ID not enough?

A. Storage ownership changes when a URL is typed.
B. Authentication makes object checks unnecessary.
C. A value naming an object does not establish permission to access it.
D. Every identifier is automatically secret forever.

Answers and explanations, page 141

Listen for the distinction

Switch roles for turns 11-20. Keep design evidence distinct from an implementation test.

Challenge the assumption, not the designer

A useful design challenge names the specific request, boundary, and missing decision. It does not accuse the architect of causing a breach. Distinguish a documented design gap from an observed production defect while making the next requirement concrete.

F Say it / transfer to a new case

Identity is not object permission

A design checks identity at sign-in but omits permission checks for individual invoices. Customers may access only their own invoices. No implementation test has run. The proposed control belongs in the service.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

identity / server / authorization / pending

01 **Architect:** The existing check establishes [1] _____.

02 **Security:** Each invoice also needs an [2] _____ check.

03 **Architect:** Enforcement belongs on the [3] _____.

04 **Security:** Implementation validation remains [4] _____.

CHECK THE GAPS

1. identity / **2.** authorization / **3.** server / **4.** pending

Why these answers fit, page 141

F Say it / transfer to a new case / continued

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "A sign-in check does not decide document access". Noor: "For validation, we can use two fictional organizations with controlled test accounts and documents in the approved environment. No live customer exploration is needed." Daniel: [missing response] Noor: "What label goes in the review: confirmed vulnerability or design gap? We have a draft in front of us, not an implementation test." Which response belongs in the gap?

A. That supports a tenant isolation check within an authorized scope. Record which account owns which document, the requested action, and the expected result before interpreting the observed outcome.

B. Let us trace the data flow. A browser sends a document identifier, the service processes it, and storage returns content. Where is permission for that particular document checked?

C. The client crosses a trust boundary. A page convention does not give the server a dependable authorization decision. We need enforcement where the service controls access to the content.

D. That leaves an authorization check unspecified. We know who signed in, but we still need the service to decide whether that user may access the requested object.

Answers and explanations, page 142

A Read the situation

LESSON 06 / GOVERNANCE, RISK, AND COMPLIANCE

Describe audit evidence, distinguish missing proof from proven failure, and state the actual closure conditions.

A written policy does not close the control finding

Control owner Rosa asks auditor Amir to close a leaver-access finding because a new policy was approved. The local control requires access removal within 24 hours of departure. In a five-person sample, three records prove timely removal; two lack removal timestamps. The agreed closure criteria require evidence for all five sampled cases and owner review. That review is not recorded. Amir must distinguish a documentation gap from proof that the two removals were late, while keeping the finding open.

People: Rosa, Control owner; Amir, Internal auditor.

Read the record

Choose one answer per question using the facts above.

1. How many sampled records prove timely removal?

A. Two of five
B. None, because no policy exists
C. Three of five
D. Five of five

2. What do the other two records lack?

A. Employee names in every case
B. A rule requiring access removal
C. Proof that a policy was approved
D. Removal timestamps

3. Can the finding close under the supplied criteria?

A. No; the briefing proves every removal was late.
B. No; evidence and owner review are incomplete.
C. Yes; a written policy replaces all operating evidence.
D. Yes; three records prove every removal was timely.

Answers and explanations, page 143

B Vocabulary in use

CORE TERMS

governance
Arrangements for directing decisions, responsibilities, and oversight.

strengthen security governance

control design
The planned way a control is meant to work.

assess control design

policy
An approved statement of required principles or rules.

approve an access policy

control owner
The role accountable for a defined control.

identify the control owner

audit trail
Records allowing actions and decisions to be traced.

preserve the audit trail

population
The full set from which assessment items are selected.

establish the population

control objective
The outcome a control is intended to achieve.

define the control objective

operating effectiveness
Whether a control works as intended over the assessed scope.

test operating effectiveness

procedure
Defined steps for carrying out a process.

maintain the removal procedure

evidence request
A specified request for records supporting an assessment.

issue an evidence request

sample
A selected subset examined in an assessment.

define the audit sample

sampling limitation
A restriction on what a sample supports about the wider set.

disclose sampling limitations

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

governance GOVERNANCE

strengthen security governance

Keep the meaning precise: Arrangements for directing decisions, responsibilities, and oversight.

procedure PROCEDURE

maintain the removal procedure

Keep the meaning precise: Defined steps for carrying out a process.

B Precision and professional shorthand

EXTEND YOUR RANGE

exception
A departure from a defined requirement or expected condition.
investigate an exception

finding
A documented assessment issue supported by stated criteria and evidence.
track an audit finding

closure criterion
A stated condition required to close an action.
satisfy closure criteria

independent review
Assessment by a sufficiently separate reviewer.
conduct an independent review

control frequency
How often a control is intended to operate.
specify control frequency

access removal
Disabling or withdrawing previously granted permissions.
evidence timely access removal

evidence gap
Missing support needed to substantiate a conclusion.
resolve an evidence gap

remediation plan
Agreed work to address an identified finding.
review the remediation plan

attestation
A formal statement affirming a specified matter.
obtain an owner attestation

retention period
The required duration for keeping records.
apply the retention period

leaver process
Handling required when a person leaves an organization.
verify the leaver process

residual risk
Risk remaining after the relevant controls or treatment.
assess residual risk

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

sampling limitation SAMPLING LIMITATION

disclose sampling limitations

Keep the meaning precise: A restriction on what a sample supports about the wider set.

closure criterion CLOSURE CRITERION

satisfy closure criteria

Keep the meaning precise: A stated condition required to close an action.

C Phrases that move the work forward

Acknowledge progress
"The new policy has been approved."

State the criterion
"Access removal is required within 24 hours."

Name the missing evidence
"Two records lack removal timestamps."

Limit the percentage
"Sixty percent of this sample has documented timely removal."

Ask for the review
"Please provide the recorded owner review."

Request traceable support
"Use the relevant system evidence and identify its source."

Keep the status accurate
"The finding remains open pending the missing evidence."

Assign the next step
"The control owner will gather the missing records."

Separate design from operation
"That does not yet establish operating effectiveness."

Give the supported count
"Three of five records prove timely removal."

Avoid a false failure claim
"We cannot determine timeliness for those two from these records."

Preserve the closure rule
"The agreed criteria require evidence for all five cases."

Avoid retroactive invention
"Do not create a timestamp as though it were an original record."

Distinguish assurance
"An assurance statement is not a substitute for the required record."

Bound the conclusion
"This sample does not establish the result for the entire population."

Close the discussion
"We will reassess closure against the same agreed criteria."

Precision in real exchanges

Purpose: Give the supported count
Useful wording: "Three of five records prove timely removal."

Purpose: Name the missing evidence
Useful wording: "Two records lack removal timestamps."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which summary is accurate?

A. Sixty percent of all employees were removed on time.

B. Three timely removals are evidenced; two are unverified; owner review is missing.

C. All five removals are proven timely because the policy exists.

D. Two late removals are proven by missing timestamps.

2. What is 3 divided by 5 in this case?

A. 60% organization-wide control effectiveness

B. A 60% proven late-removal rate

C. Proof that the two undocumented cases were timely

D. 60% of the sample with documented timely removal

3. A colleague needs the term for this meaning: Whether a control works as intended over the assessed scope. Which term fits?

A. finding

B. audit trail

C. operating effectiveness

D. control frequency

D Choose the response that fits / continued

4. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "Could I say the control was sixty percent effective? Three out of five is sixty percent, and that seems more concise for the committee." Amir: [missing response] Rosa: "I agree about not calling them late without evidence. The help desk thinks the removals happened, but we do not yet have the original supporting records." Which response belongs in the gap?

A. An attestation may be relevant context, but it does not replace the specific records required here. We should not silently change the closure standard at the end.

B. Then operating effectiveness is not established for all five. We should not describe the policy document as if it were evidence of each actual removal.

C. That preserves the audit trail. We need a traceable account of the assessment, including any later records or corrections, not a headline that hides unresolved support.

D. Report the sample accurately: sixty percent has documented timely removal. That does not establish organization-wide effectiveness, and it does not prove the other two were late.

Answers and explanations, page 143

One useful distinction

Three of five is 60% of the sample with documented timely removal. It is not a demonstrated 60% organization-wide effectiveness rate. The two missing timestamps do not establish whether those removals were timely or late.

E Conversation

A written policy does not close the control finding

A written policy does not close the control finding

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

sample / control owner / evidence gap / audit trail / sampling limitation / attestation / closure criteria / operating effectiveness / remediation plan / control design

01 **Rosa:** The new leaver policy is approved. It requires removal within twenty-four hours, and I would like the audit action marked closed before the committee meeting.

02 **Amir:** Policy approval is useful progress on [1] _____, but closure also requires evidence that the control operated. Let us compare the supplied records with the criteria we agreed.

03 **Rosa:** We selected five leavers. Three records include departure and removal times within the required period. The other two do not include removal timestamps.

04 **Amir:** Then [2] _____ is not established for all five. We should not describe the policy document as if it were evidence of each actual removal.

05 **Rosa:** Could I say the control was sixty percent effective? Three out of five is sixty percent, and that seems more concise for the committee.

06 **Amir:** Report the [3] _____ accurately: sixty percent has documented timely removal. That does not establish organization-wide effectiveness, and it does not prove the other two were late.

E Conversation / continued

07 **Rosa:** I agree about not calling them late without evidence. The help desk thinks the removals happened, but we do not yet have the original supporting records.

08 **Amir:** That is an [4] _____. Request the relevant system records and identify their source. A recollection can guide the search, but it should not become an invented historical timestamp.

09 **Rosa:** The closure note says evidence for every sampled case and owner review. I have not completed a recorded review because the two records are still missing.

10 **Amir:** Those are the [5] _____ we must use. The finding remains open until the missing support and required review are addressed, rather than closing merely because the policy now exists.

Conversation continues on the next page.

A written policy does not close the control finding

CONVERSATION / CONTINUED

11 **Rosa:** The committee will ask why it is still open. Can we show the approved policy and three supported cases without implying the remaining work is done?

12 **Amir:** Show that in the [6] _____. Completed work and an open finding can coexist. A progress update should say what changed and what still prevents the agreed closure.

13 **Rosa:** I will assign the record retrieval and keep the committee wording bounded. For the missing cases, I will use timeliness unverified rather than late.

14 **Amir:** That preserves the [7] _____. We need a traceable account of the assessment, including any later records or corrections, not a headline that hides unresolved support.

15 **Rosa:** Could I sign a statement about our normal process? I can describe what the team does, but I cannot supply those two times yet.

16 **Amir:** An [8] _____ may be relevant context, but it does not replace the specific records required here. We should not silently change the closure standard at the end.

17 **Rosa:** Understood. I will separate approval of the policy, evidence for three timely removals, two unverified cases, and the owner review still to be recorded.

18 **Amir:** Also state the [9] _____. We examined five records; we have not established the result for every leaver. The percentage needs both its denominator and its evidence meaning.

19 **Rosa:** Then I can give the committee a truthful progress report and a clear remaining action, without claiming that missing documentation proves misconduct or lateness.

20 **Amir:** Exactly. The [10] _____ can bring the missing evidence for reassessment. We will evaluate closure against the same criteria and record the conclusion the completed support actually justifies.

CHECK THE GAPS

1. control design / **2.** operating effectiveness / **3.** sample / **4.** evidence gap / **5.** closure criteria / **6.** remediation plan / **7.** audit trail / **8.** attestation / **9.** sampling limitation / **10.** control owner

Why these answers fit, page 145

F Check accuracy and scope

A written policy does not close the control finding

Return to the case

Control owner Rosa asks auditor Amir to close a leaver-access finding because a new policy was approved. The local control requires access removal within 24 hours of departure. In a five-person sample, three records prove timely removal; two lack removal timestamps. The agreed closure criteria require evidence for all five sampled cases and owner review. That review is not recorded. Amir must distinguish a documentation gap from proof that the two removals were late, while keeping the finding open.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. Which evidence request is appropriately specific?

A. Replace the missing timestamps with estimates presented as original records.
B. Repeat the policy approval date as proof of all removals.
C. Provide source records for the two removal times and the owner review.
D. Please send anything that looks reassuring.

2. Why should the finding remain open?

A. A new policy can never support a control.
B. Every missing record proves deliberate misconduct.
C. The auditor dislikes the control owner.
D. The agreed evidence and review conditions are not met.

Answers and explanations, page 146

Listen for the distinction

Switch roles for turns 11-20. Stress sample limits and the required owner review.

Make the evidence request specific

A challenge to closure need not dismiss the work already completed. Acknowledge the approved policy, then name the missing records and review. Avoid both extremes: treating paperwork as operating proof or calling every undocumented action a proven late removal.

F Say it / transfer to a new case

Missing proof is not a proven delay

A four-case access-removal sample has three documented timely removals and one missing timestamp. Closure requires evidence for all four and an owner review. Neither the missing evidence nor the review is complete.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

timestamp / review / closure / timeliness

01 **Auditor:** For the fourth case, we still need the removal [1] _____.

02 **Owner:** Without it, I cannot verify that case's [2] _____.

03 **Auditor:** We also need the recorded owner [3] _____.

04 **Owner:** Keep the finding open until the evidence and review meet our conditions for [4] _____.

CHECK THE GAPS

1. timestamp / **2.** timeliness / **3.** review / **4.** closure

Why these answers fit, page 146

F Say it / transfer to a new case / continued

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "I will assign the record retrieval and keep the committee wording bounded. For the missing cases, I will use timeliness unverified rather than late." Amir: [missing response] Rosa: "Could I sign a statement about our normal process? I can describe what the team does, but I cannot supply those two times yet." Which response belongs in the gap?

A. Then operating effectiveness is not established for all five. We should not describe the policy document as if it were evidence of each actual removal.

B. Report the sample accurately: sixty percent has documented timely removal. That does not establish organization-wide effectiveness, and it does not prove the other two were late.

C. An attestation may be relevant context, but it does not replace the specific records required here. We should not silently change the closure standard at the end.

D. That preserves the audit trail. We need a traceable account of the assessment, including any later records or corrections, not a headline that hides unresolved support.

Answers and explanations, page 147

Review 3 / Meaning and context

Use language from the lessons you have completed. Choose one answer per question.

> **Case file**
>
> Revisit "Threat Modeling and Secure Design" and "Governance, Risk, and Compliance". Choose precise terminology, then reconstruct the missing responses using both neighboring turns. The final two questions also revisit earlier conversations.

1. A colleague needs the term for this meaning: A point where assumptions about control or trust change. Which term fits?

A. spoofing

B. trust boundary

C. tenant

D. entry point

2. A colleague needs the term for this meaning: A specified request for records supporting an assessment. Which term fits?

A. independent review

B. evidence request

C. governance

D. exception

3. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "That gives me the identity and sign-in requirements. For timing, I can specify a two-hour window rather than leaving the access available indefinitely." Rashid: [missing response] Eva: "I have submitted the request, but the owner has not signed off. What can I tell the technicians while that decision is pending?" Which response belongs in the gap?

A. Our policy requires a named account for each technician. A private agreement about sharing does not replace individual attribution or the access conditions we have been asked to enforce.

B. Let us start with least privilege. The supplied task needs read access to sanitized diagnostic logs for two hours. Which part requires changing the system or administering it?

C. Make it time-bound access with a recorded end. Short work does not justify standing privilege, and the duration should be visible to whoever reviews and implements the request.

D. We require multifactor authentication. We need to verify that the approved arrangement meets it, not rely on the general adjective secure or treat vendor familiarity as an exemption.

Review 3 / Meaning and context / continued

4. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "Understood. I will separate approval of the policy, evidence for three timely removals, two unverified cases, and the owner review still to be recorded." Amir: [missing response] Rosa: "Then I can give the committee a truthful progress report and a clear remaining action, without claiming that missing documentation proves misconduct or lateness." Which response belongs in the gap?

A. Also state the sampling limitation. We examined five records; we have not established the result for every leaver. The percentage needs both its denominator and its evidence meaning.

B. Policy approval is useful progress on control design, but closure also requires evidence that the control operated. Let us compare the supplied records with the criteria we agreed.

C. Show that in the remediation plan. Completed work and an open finding can coexist. A progress update should say what changed and what still prevents the agreed closure.

D. Exactly. The control owner can bring the missing evidence for reassessment. We will evaluate closure against the same criteria and record the conclusion the completed support actually justifies.

Answers and explanations, page 164

A Read the situation

LESSON 07 / SECURITY AWARENESS AND PHISHING

Elicit a precise suspicious-message report, encourage prompt disclosure, and avoid requests for secrets or unsupported reassurance.

> **Report the click, without guessing the consequence**
>
> Employee Ben calls security responder Leila about an email claiming to be from Payroll. He clicked its link at 09:32 UTC and reported it at 09:36. He says he entered no credentials, opened no attachment, and approved no sign-in prompt. He worries that reporting will get him blamed. The message has not been classified, and compromise is not established. The local process routes the original message through the approved reporting tool. Leila asks for factual details, not passwords, and tells Ben not to interact further while the response team assesses it.

People: Ben, Employee reporter; Leila, Security responder.

Read the record

Choose one answer per question using the facts above.

1. What did Ben report doing?

A. Entering a password and approving every prompt
B. Downloading an attachment and running it
C. Confirming that Payroll sent the email
D. Clicking the link without entering credentials, opening an attachment, or approving a prompt

2. How long after the click did Ben report it?

A. Thirty-six minutes
B. Four hours
C. Four minutes
D. Thirty-two minutes

3. What is the message status?

A. A confirmed breach of every account
B. Proven harmless because no password was entered
C. Not yet classified
D. Confirmed legitimate payroll communication

Answers and explanations, page 148

B Vocabulary in use

CORE TERMS

phishing
Deceptive communication intended to induce unsafe disclosure or action.

report suspected phishing

social engineering
Manipulating people to gain information or access.

recognize social-engineering tactics

pretext
A claimed reason used to justify a request.

identify the pretext

impersonation
Pretending to be a trusted person or organization.

assess possible impersonation

display name
The sender label shown by a message interface.

inspect the display name

sender address
The address presented as the origin of a message.

verify the sender address

reply-to address
The destination used when replying to a message.

compare the reply-to address

message header
Technical metadata associated with an email.

preserve message headers

link destination
The address to which a link points.

assess the link destination

attachment
A file included with a message.

report an unexpected attachment

credential
Information or a token used to support authentication.

protect authentication credentials

credential harvesting
Deceptively collecting authentication information.

investigate credential harvesting

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

phishing PHISHING

report suspected phishing

Keep the meaning precise: Deceptive communication intended to induce unsafe disclosure or action.

sender address SENDER ADDRESS

verify the sender address

Keep the meaning precise: The address presented as the origin of a message.

B Precision and professional shorthand

EXTEND YOUR RANGE

MFA prompt
A request for an additional authentication step.
report an unexpected MFA prompt

out-of-band verification
Checking through a separate trusted communication route.
use out-of-band verification

reporting tool
An approved mechanism for submitting suspicious content.
use the reporting tool

intake
Initial collection of facts for assessment.
complete security intake

message classification
An assessed category assigned to a message.
confirm message classification

quarantine
Controlled separation of suspicious content or systems.
verify quarantine status

urgency cue
Language pressuring someone to act quickly.
identify an urgency cue

known contact channel
A previously verified way to reach a person or team.
use a known contact channel

reporter
A person who raises a concern or observation.
acknowledge the reporter

interaction history
A factual account of actions taken with content.
record interaction history

compromise
Loss of the intended security of an account or system.
investigate possible compromise

reporting delay
Time between a relevant event and its report.
measure reporting delay

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

credential harvesting CREDENTIAL HARVESTING

investigate credential harvesting

Keep the meaning precise: Deceptively collecting authentication information.

reporting tool REPORTING TOOL

use the reporting tool

Keep the meaning precise: An approved mechanism for submitting suspicious content.

C Phrases that move the work forward

Welcome the report
"Thank you for reporting it promptly."

Locate the event
"What time did you click the link?"

Protect secrets
"Do not tell me your password."

Avoid premature reassurance
"We have not established whether there was any compromise."

Use the approved route
"Submit the original through the reporting tool."

Avoid ordinary forwarding
"Use the approved tool, not a wider distribution list."

Name the pretext
"The message claims that payroll action is urgent."

Support disclosure
"Accurate details help us choose the right response."

Ask neutrally
"What did you do after opening the message?"

Separate the actions
"Did you enter credentials, open a file, or approve a sign-in prompt?"

Attribute the account
"You report that no credentials were entered."

Stop further interaction
"Do not interact with the message further."

Preserve relevant details
"Keep the message details available for the response team."

Verify independently
"Use a known Payroll contact channel for any business confirmation."

Keep classification open
"The message is still under assessment."

Close with a clear next step
"The response team will assess the report and provide instructions."

Precision in real exchanges

Purpose: Separate the actions
Useful wording: "Did you enter credentials, open a file, or approve a sign-in prompt?"

Purpose: Protect secrets
Useful wording: "Do not tell me your password."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which opening is most useful?

A. Tell me your password so I can check it.

B. Thank you for reporting. What actions did you take, and when?

C. Why would anyone fall for that?

D. Nothing can happen if you entered no password.

2. Which status accurately reflects the facts?

A. The link click proves all credentials were stolen.

B. A suspicious-message report is under assessment; compromise is not established.

C. Every payroll account has been breached.

D. The email is safe because its display name says Payroll.

3. A colleague needs the term for this meaning: Pretending to be a trusted person or organization. Which term fits?

A. link destination

B. message classification

C. out-of-band verification

D. impersonation

D Choose the response that fits / continued

4. Rebuild the exchange from "Report the click, without guessing the consequence". Ben: "I clicked at nine thirty-two UTC and reported it at nine thirty-six. A page opened. I did not type anything into it." Leila: [missing response] Ben: "No credentials, no attachment, and no prompt approval. I can give you my password if that helps you check whether the account was affected." Which response belongs in the gap?

A. Please do not share any credential. We do not need your password in this conversation. We need the account identifier and factual actions through the approved response process.

B. I will record the interaction history. Did you enter credentials, open an attachment, or approve a sign-in prompt? Those are separate actions, and we need each one described accurately.

C. Use the approved reporting tool for the original. Do not distribute the message more widely or interact further. The response team will assess it and coordinate any necessary communication.

D. That display name is useful context, but it does not verify the sender. Tell me the click time and what appeared next, without interacting with the message again.

Answers and explanations, page 148

> **One useful distinction**
>
> No credentials entered is important reported information, not proof that no risk exists. Preserve what the employee says as a report until corroborated where needed. Message appearance and a familiar display name do not establish authenticity.

E Conversation

Report the click, without guessing the consequence

Report the click, without guessing the consequence

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

reporting tool / out-of-band verification / credential / compromise / Message classification / interaction history / intake / reporting delay / reporting promptly / display name

01 **Ben:** I clicked a payroll email and now I am worried it was suspicious. I reported it quickly, but I am concerned that I will be blamed.

02 **Leila:** Thank you for [1] _____. Accurate details help the response. Let us go through what you actually did, without guessing the consequence.

03 **Ben:** The email said I needed to confirm payroll information urgently. It showed Payroll as the sender name, so I assumed it came from our team.

04 **Leila:** That [2] _____ is useful context, but it does not verify the sender. Tell me the click time and what appeared next, without interacting with the message again.

05 **Ben:** I clicked at nine thirty-two UTC and reported it at nine thirty-six. A page opened. I did not type anything into it.

06 **Leila:** I will record the [3] _____. Did you enter credentials, open an attachment, or approve a sign-in prompt? Those are separate actions, and we need each one described accurately.

07 **Ben:** No credentials, no attachment, and no prompt approval. I can give you my password if that helps you check whether the account was affected.

08 **Leila:** Please do not share any [4] _____. We do not need your password in this conversation. We need the account identifier and factual actions through the approved response process.

09 **Ben:** I did not enter anything. Can I tell my manager the account is safe, or do you still need to check?

10 **Leila:** We have not established [5] _____, and I cannot give an all-clear from that fact alone. Your report narrows the assessment; it does not replace it.

Conversation continues on the next page.

Report the click, without guessing the consequence

CONVERSATION / CONTINUED

11 **Ben:** Understood. I still have the original email. Should I forward it to everyone in my department so they can recognize it and avoid clicking?

12 **Leila:** Use the approved [6] _____ for the original. Do not distribute the message more widely or interact further. The response team will assess it and coordinate any necessary communication.

13 **Ben:** I will use that route. The message also gives a phone number for Payroll. Should I call that number to ask whether they sent it?

14 **Leila:** Use [7] _____ through a Payroll channel you already know is genuine. A number supplied only in the suspicious message would rely on the same unverified source.

15 **Ben:** I can reach Payroll through our established internal contact. For the security report, I will keep the times and the original message available.

16 **Leila:** Good. The [8] _____ was four minutes in this case. Prompt reporting gives us useful information sooner, but we still need the assessment before describing the outcome.

17 **Ben:** I almost left out the click. I felt embarrassed and thought the fact that I had not entered a password was the important part.

18 **Leila:** Complete [9] _____ depends on those details. Please keep the account accurate. I can explain our response steps, but I should not make promises about decisions outside my role.

19 **Ben:** My manager can hear that I clicked, reported four minutes later, and did not enter credentials, open an attachment, or approve a prompt. Assessment is pending.

20 **Leila:** Exactly. [10] _____ is still open. Submit the original through the approved tool and follow the response team's instructions. Do not treat either embarrassment or reassurance as evidence.

CHECK THE GAPS

1. reporting promptly / **2.** display name / **3.** interaction history / **4.** credential / **5.** compromise / **6.** reporting tool / **7.** out-of-band verification / **8.** reporting delay / **9.** intake / **10.** Message classification

Why these answers fit, page 150

F Check accuracy and scope

Report the click, without guessing the consequence

Return to the case

Employee Ben calls security responder Leila about an email claiming to be from Payroll. He clicked its link at 09:32 UTC and reported it at 09:36. He says he entered no credentials, opened no attachment, and approved no sign-in prompt. He worries that reporting will get him blamed. The message has not been classified, and compromise is not established. The local process routes the original message through the approved reporting tool. Leila asks for factual details, not passwords, and tells Ben not to interact further while the response team assesses it.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. What should Ben use to submit the original?

A. The approved reporting tool
B. A message to every colleague
C. A reply to the suspicious sender asking permission
D. Repeated clicks to reproduce the issue on other devices

2. Which confirmation route avoids trusting the suspicious message?

A. The phone number supplied only in that email
B. The message's reply-to address without checking
C. The linked page's assurance that it is genuine
D. A previously verified Payroll contact channel

Answers and explanations, page 151

Listen for the distinction

Switch roles for turns 11-20. Stress the trusted reporting route without promising an all-clear.

Make accurate reporting easier

Thank the person for reporting and ask neutral, concrete questions about actions. Do not promise immunity from every workplace consequence or declare the device safe without evidence. Reassurance should support truthful disclosure and the reporting process, not substitute for assessment.

F Say it / transfer to a new case

Report actions separately

An employee clicked a suspicious link at 14:10 UTC and reported it at 14:17. They report no credential entry. Message classification is pending. The approved tool is the required reporting route.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

tool / pending / seven / credential

01 **Responder:** The reporting interval was [1] _____ minutes.

02 **Employee:** I report no [2] _____ entry.

03 **Responder:** Message classification is [3] _____.

04 **Employee:** I will use the approved reporting [4] _____.

CHECK THE GAPS

1. seven / **2.** credential / **3.** pending / **4.** tool

Why these answers fit, page 151

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "Report the click, without guessing the consequence". Ben: "I will use that route. The message also gives a phone number for Payroll. Should I call that number to ask whether they sent it?" Leila: [missing response] Ben: "I can reach Payroll through our established internal contact. For the security report, I will keep the times and the original message available." Which response belongs in the gap?

A. Use out-of-band verification through a Payroll channel you already know is genuine. A number supplied only in the suspicious message would rely on the same unverified source.

B. That display name is useful context, but it does not verify the sender. Tell me the click time and what appeared next, without interacting with the message again.

C. Please do not share any credential. We do not need your password in this conversation. We need the account identifier and factual actions through the approved response process.

D. Good. The reporting delay was four minutes in this case. Prompt reporting gives us useful information sooner, but we still need the assessment before describing the outcome.

Answers and explanations, page 152

A Read the situation

LESSON 08 / EXECUTIVE RISK BRIEFINGS

Connect a measured security gap to a business consequence and a specific investment request without claiming guaranteed risk elimination.

A recovery shortfall needs a bounded decision

Security lead Imani briefs finance sponsor Victor on payroll resilience. A controlled recovery test took six hours against an approved four-hour recovery-time objective. It did not establish data loss, and no live incident is occurring. Payroll normally processes 200 scheduled records per hour. A four-hour interruption would defer 800 records at that assumed rate, not prove lost revenue. Proposal A requests $30,000 for recovery automation and repeat testing. Proposal B requests $20,000 for alert-dashboard improvements. The agreed priority is the evidenced payroll recovery shortfall; Victor must decide on A.

People: Imani, Security lead; Victor, Finance sponsor.

Read the record

Choose one answer per question using the facts above.

1. How far did the test exceed the recovery-time objective?

A. Four hours
B. Six hours
C. Eight hundred hours
D. Two hours

2. What does the 800-record illustration mean?

A. Deferred processing during four hours at the assumed rate
B. Proven lost revenue of $800
C. Confirmed destruction of 800 records
D. A measured live-incident backlog

3. What decision is requested?

A. Approval of an already completed live recovery
B. $30,000 for recovery automation and repeat testing
C. $20,000 for a payroll data-loss payment
D. A declaration that all cyber risk is eliminated

Answers and explanations, page 153

B Vocabulary in use

CORE TERMS

risk scenario
A defined chain of conditions, event, and consequence.

describe a risk scenario

risk exposure
The potential for loss or harm under stated conditions.

explain risk exposure

business consequence
An effect on operations, obligations, or objectives.

connect to a business consequence

likelihood
An assessment of how probable an event is.

qualify the likelihood estimate

impact estimate
A bounded assessment of potential consequences.

state the impact estimate

uncertainty range
An interval expressing limits on an estimate.

report an uncertainty range

recovery-time objective
The target time for restoring a capability after disruption.

test the recovery-time objective

recovery-point objective
The target limit on data loss measured in time.

distinguish the recovery-point objective

recovery test
A controlled exercise of restoration capabilities.

run a recovery test

resilience
Capacity to withstand disruption and restore required function.

improve operational resilience

processing backlog
Work awaiting processing after capacity or availability is lost.

estimate the processing backlog

deferred processing
Work delayed rather than necessarily lost.

quantify deferred processing

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

risk scenario RISK SCENARIO

describe a risk scenario

Keep the meaning precise: A defined chain of conditions, event, and consequence.

uncertainty range UNCERTAINTY RANGE

report an uncertainty range

Keep the meaning precise: An interval expressing limits on an estimate.

B Precision and professional shorthand

EXTEND YOUR RANGE

service interruption

A period when a service is unavailable or impaired.

assess service interruption

investment case

Reasons, costs, and expected outcomes supporting expenditure.

present an investment case

funding envelope

The defined amount available or requested for work.

specify the funding envelope

success measure

A defined basis for judging a proposed outcome.

agree success measures

risk appetite

The amount and type of risk an organization is willing to pursue or retain.

clarify risk appetite

residual exposure

The relevant exposure remaining after a proposed measure.

disclose residual exposure

risk treatment

An action or decision to address a specified risk.

select risk treatment

decision request

A precise action sought from an authorized decision maker.

frame the decision request

implementation dependency

A prerequisite for carrying out a proposed change.

identify implementation dependencies

assurance evidence

Support for confidence that an intended capability works.

collect assurance evidence

tolerance threshold

A defined boundary for acceptable deviation or exposure.

specify a tolerance threshold

review trigger

A condition requiring renewed assessment or decision.

define a review trigger

Say it in context

Stress the highlighted expression. Keep the surrounding words connected; pause at the end of the phrase.

deferred processing DEFERRED PROCESSING

quantify deferred processing

Keep the meaning precise: Work delayed rather than necessarily lost.

funding envelope FUNDING ENVELOPE

specify the funding envelope

Keep the meaning precise: The defined amount available or requested for work.

C Phrases that move the work forward

Lead with the gap
"The test took six hours against a four-hour objective."

Separate test from incident
"This is a controlled test result, not a live outage."

Give the assumption
"The illustration assumes 200 scheduled records per hour."

Reject false loss language
"Deferred records are not automatically lost revenue."

Name the work
"The scope is recovery automation and repeat testing."

Represent the alternative
"B improves alert dashboards but does not directly address this test result."

Define success
"Repeat the agreed test against the four-hour objective."

Keep authority explicit
"Funding remains subject to your decision."

State the difference
"That is a two-hour shortfall against the target."

Translate the operation
"An interruption would delay payroll processing."

Use the right unit
"Four hours would defer 800 records at that rate."

State the request
"I am requesting $30,000 for proposal A."

Connect the priority
"A directly addresses the measured recovery shortfall."

Avoid a guarantee
"The proposal needs evidence that recovery performance improves."

Disclose remaining risk
"This does not remove every security exposure."

Close the briefing
"Approve or decline A on this scope, with results reviewed after testing."

Precision in real exchanges

Purpose: Translate the operation
Useful wording: "An interruption would delay payroll processing."

Purpose: Give the assumption
Useful wording: "The illustration assumes 200 scheduled records per hour."

D Choose the response that fits

Choose one response for each situation. Preserve the facts, the decision boundary, and the purpose of the exchange.

1. Which opening is most decision-ready?

A. A six-hour recovery test missed the four-hour objective; I request $30,000 to automate and retest.

B. We have many tools and technical concerns.

C. A live attack has destroyed all payroll data.

D. The dashboard has attractive features, so all risk is solved.

2. Which statement about data loss is supported?

A. Four-hour RTO guarantees zero data loss.

B. Eight hundred deferred records were permanently deleted.

C. The supplied test does not establish data loss.

D. Six hours of recovery proves six hours of data loss.

3. A colleague needs the term for this meaning: An assessment of how probable an event is. Which term fits?

A. recovery test

B. investment case

C. risk appetite

D. likelihood

D Choose the response that fits / continued

4. Rebuild the exchange from "A recovery shortfall needs a bounded decision". Victor: "Then explain the business consequence in operational terms. I want the committee to understand the exposure without hearing an unsupported claim about a current attack." Imani: [missing response] Victor: "That is a useful scale. But eight hundred records does not mean eight hundred customers permanently lost, or eight hundred dollars of lost revenue." Which response belongs in the gap?

A. No. Residual exposure remains, and this work addresses one defined capability. Faster recovery does not establish prevention of every incident or eliminate every consequence of disruption.

B. A service interruption would delay payroll processing. At the stated rate of two hundred scheduled records per hour, a four-hour interruption would defer eight hundred records.

C. Correct. This is deferred processing, not a calculated revenue loss. The rate is an assumption for the illustration, and there is no live incident in this briefing.

D. The success measure is performance in the agreed repeat test against the four-hour objective. We need that evidence before claiming that the restoration capability meets the target.

Answers and explanations, page 153

One useful distinction

The test exceeded its four-hour objective by two hours, or 50% of that objective. A recovery-time objective concerns restoration time; a recovery-point objective concerns tolerable data loss in time. One does not establish the other.

E Conversation

A recovery shortfall needs a bounded decision

A recovery shortfall needs a bounded decision

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

decision request / success measure / funding envelope / assurance evidence / recovery test / service interruption / recovery-time objective / Residual exposure / risk treatment / deferred processing

01 **Victor:** The proposal lists several technical weaknesses. I need to know what decision you want and why this work comes before the dashboard upgrade.

02 **Imani:** Our [1] _____ took six hours against an approved four-hour target. I am requesting thirty thousand dollars for recovery automation and repeat testing to address that measured gap.

03 **Victor:** So we missed the target by two hours. Is that a statement about how long payroll data was lost, or how long restoration took?

04 **Imani:** It concerns the [2] _____. We measured restoration time. The test does not establish data loss, and I should not describe the six-hour result as six hours of lost information.

05 **Victor:** Then explain the business consequence in operational terms. I want the committee to understand the exposure without hearing an unsupported claim about a current attack.

06 **Imani:** A [3] _____ would delay payroll processing. At the stated rate of two hundred scheduled records per hour, a four-hour interruption would defer eight hundred records.

E Conversation / continued

07 **Victor:** That is a useful scale. But eight hundred records does not mean eight hundred customers permanently lost, or eight hundred dollars of lost revenue.

08 **Imani:** Correct. This is [4] _____, not a calculated revenue loss. The rate is an assumption for the illustration, and there is no live incident in this briefing.

09 **Victor:** What exactly does the thirty thousand fund? I do not want an approval interpreted as a general authorization for unrelated tooling later in the year.

10 **Imani:** The [5] _____ covers proposal A: recovery automation and repeat testing. Any additional scope or funding would need its own decision rather than being implied by this approval.

Conversation continues on the next page.

A recovery shortfall needs a bounded decision

CONVERSATION / CONTINUED

11 **Victor:** The dashboard is ten thousand dollars cheaper. Why not buy that first? Tell me how each option addresses the gap we actually measured.

12 **Imani:** It could improve alert visibility, but our agreed [6] _____ priority is the evidenced payroll recovery shortfall. A is directly aimed at that gap; B does not directly address this test result.

13 **Victor:** How will we know whether the automation works? A purchase receipt will show spending, but it will not show that recovery has become faster.

14 **Imani:** The [7] _____ is performance in the agreed repeat test against the four-hour objective. We need that evidence before claiming that the restoration capability meets the target.

15 **Victor:** If the repeat test meets four hours, what risk remains? I need that limitation in the committee note, not just the improvement headline.

16 **Imani:** No. [8] _____ remains, and this work addresses one defined capability. Faster recovery does not establish prevention of every incident or eliminate every consequence of disruption.

17 **Victor:** That distinction belongs in the committee note. We have a measured gap, a conditional operational illustration, a bounded proposal, and a validation requirement.

18 **Imani:** I will include the [9] _____ expected from the repeat test and identify any implementation dependencies. The recommendation should show what must be demonstrated, not just what we hope to buy.

A recovery shortfall needs a bounded decision / continued

19 **Victor:** I can now evaluate the request against the agreed priority. Please keep the approval status open until I record the decision on that specific scope.

20 **Imani:** Understood. The [10] _____ is approval of A for thirty thousand dollars, with results reviewed after testing. I will not describe the funding or the improvement as already secured.

CHECK THE GAPS

1. recovery test / **2.** recovery-time objective / **3.** service interruption / **4.** deferred processing / **5.** funding envelope / **6.** risk treatment / **7.** success measure / **8.** Residual exposure / **9.** assurance evidence / **10.** decision request

Why these answers fit, page 154

F Check accuracy and scope

A recovery shortfall needs a bounded decision

Return to the case

Security lead Imani briefs finance sponsor Victor on payroll resilience. A controlled recovery test took six hours against an approved four-hour recovery-time objective. It did not establish data loss, and no live incident is occurring. Payroll normally processes 200 scheduled records per hour. A four-hour interruption would defer 800 records at that assumed rate, not prove lost revenue. Proposal A requests $30,000 for recovery automation and repeat testing. Proposal B requests $20,000 for alert-dashboard improvements. The agreed priority is the evidenced payroll recovery shortfall; Victor must decide on A.

Choose one answer per question. Use the case facts and keep any uncertainty or limits intact.

1. Why does A rank ahead under the stated priority?

A. B can never have any security value.
B. The test proves every dashboard is useless.
C. It directly addresses the evidenced payroll recovery shortfall.
D. It costs more, so it must be better.

2. What should follow the proposed automation?

A. Replace the target with six hours without a decision.
B. Claim all attacks are now impossible.
C. Repeat the agreed recovery test and assess evidence against the objective.
D. Declare success on purchase alone.

Answers and explanations, page 156

Listen for the distinction

Switch roles for turns 11-20. Contrast requested funding with demonstrated improvement.

Give the decision before the technical inventory

Executive listeners need the measured gap, its operational meaning, the proposed response, and the approval requested. Acknowledge alternatives fairly. Avoid converting a scenario into a forecast or a test result into a claim that a current attack is under way.

F Say it / transfer to a new case

Translate the number without changing its meaning

A recovery test takes five hours against a three-hour objective. At an assumed 100 scheduled records per hour, a three-hour interruption would defer work. No data loss or live incident is established.

Complete the four gaps. With a partner, read alternate roles, then switch. Studying alone, read both roles and pause before each response.

WORD AND PHRASE BANK

300 / 100 / two / unestablished

01 **Security:** The test exceeded the objective by [1] _____ hours.

02 **Sponsor:** The illustration uses [2] _____ records per hour.

03 **Security:** Three hours would defer [3] _____ records.

04 **Sponsor:** Data loss remains [4] _____.

CHECK THE GAPS

1. two / **2.** 100 / **3.** 300 / **4.** unestablished

Why these answers fit, page 156

F Say it / transfer to a new case / continued

Rebuild the exchange

Choose the missing response. Read the completed three-turn exchange aloud, changing roles on the second reading.

1. Rebuild the exchange from "A recovery shortfall needs a bounded decision". Victor: "How will we know whether the automation works? A purchase receipt will show spending, but it will not show that recovery has become faster." Imani: [missing response] Victor: "If the repeat test meets four hours, what risk remains? I need that limitation in the committee note, not just the improvement headline." Which response belongs in the gap?

A. A service interruption would delay payroll processing. At the stated rate of two hundred scheduled records per hour, a four-hour interruption would defer eight hundred records.

B. Our recovery test took six hours against an approved four-hour target. I am requesting thirty thousand dollars for recovery automation and repeat testing to address that measured gap.

C. The success measure is performance in the agreed repeat test against the four-hour objective. We need that evidence before claiming that the restoration capability meets the target.

D. Correct. This is deferred processing, not a calculated revenue loss. The rate is an assumption for the illustration, and there is no live incident in this briefing.

Answers and explanations, page 157

Review 4 / Meaning and context

Use language from the lessons you have completed. Choose one answer per question.

> **Case file**
>
> Revisit "Security Awareness and Phishing" and "Executive Risk Briefings". Choose precise terminology, then reconstruct the missing responses using both neighboring turns. The final two questions also revisit earlier conversations.

1. A colleague needs the term for this meaning: A claimed reason used to justify a request. Which term fits?

A. message header
B. pretext
C. interaction history
D. urgency cue

2. A colleague needs the term for this meaning: The target limit on data loss measured in time. Which term fits?

A. risk scenario
B. service interruption
C. success measure
D. recovery-point objective

3. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "The closure note says evidence for every sampled case and owner review. I have not completed a recorded review because the two records are still missing." Amir: [missing response] Rosa: "The committee will ask why it is still open. Can we show the approved policy and three supported cases without implying the remaining work is done?" Which response belongs in the gap?

A. Policy approval is useful progress on control design, but closure also requires evidence that the control operated. Let us compare the supplied records with the criteria we agreed.
B. Show that in the remediation plan. Completed work and an open finding can coexist. A progress update should say what changed and what still prevents the agreed closure.
C. Those are the closure criteria we must use. The finding remains open until the missing support and required review are addressed, rather than closing merely because the policy now exists.
D. That is an evidence gap. Request the relevant system records and identify their source. A recollection can guide the search, but it should not become an invented historical timestamp.

Review 4 / Meaning and context / continued

4. Rebuild the exchange from "A recovery shortfall needs a bounded decision". Victor: "That distinction belongs in the committee note. We have a measured gap, a conditional operational illustration, a bounded proposal, and a validation requirement." Imani: [missing response] Victor: "I can now evaluate the request against the agreed priority. Please keep the approval status open until I record the decision on that specific scope." Which response belongs in the gap?

A. It concerns the recovery-time objective. We measured restoration time. The test does not establish data loss, and I should not describe the six-hour result as six hours of lost information.

B. Understood. The decision request is approval of A for thirty thousand dollars, with results reviewed after testing. I will not describe the funding or the improvement as already secured.

C. I will include the assurance evidence expected from the repeat test and identify any implementation dependencies. The recommendation should show what must be demonstrated, not just what we hope to buy.

D. It could improve alert visibility, but our agreed risk treatment priority is the evidenced payroll recovery shortfall. A is directly aimed at that gap; B does not directly address this test result.

Answers and explanations, page 167

Language for the next case

Deleting the post does not revoke the credential

revocation

Revocation disables the credential itself; deleting a visible copy does not prevent someone who already obtained it from using it.

Malik: No. Removing the post does not perform revocation. The token is still active, and someone may already have copied it.

credential identifier

The credential identifier lets responders locate the relevant record without reproducing the authentication secret in another channel.

Malik: Use that credential identifier. I am authorizing revocation through our response process now. Notify the owner that dependent work may be interrupted.

secret store

The secret store is the controlled mechanism for holding and delivering sensitive credentials; a general configuration ticket would create another exposed copy.

Malik: No. Use the approved secret store. The ticket can reference the controlled record and owner without containing the replacement secret.

rotation

Rotation replaces a credential and moves authorized consumers to the replacement; it does not by itself determine whether the exposed credential was misused.

Malik: The rotation can be completed and recorded separately. Do not use that completion to claim there was no earlier unauthorized activity.

blast radius

Blast radius is the scope of affected services or access; discovering another dependent job changes the operational impact assessment.

Malik: Add it and assess the interruption. That also changes the blast radius we understood, so update the impact note rather than leave the first description unqualified.

audit log

The audit log provides recorded activity for the available period; missing coverage prevents an unrestricted claim that no misuse occurred.

Malik: Keep that limit beside the audit log result. No unexplained use found in those records is narrower than proof that nobody used the token.

Read the phrases aloud. Then complete the conversation on the following pages using the word bank.

Conversation

Deleting the post does not revoke the credential

An engineer posted a live service token in a public support snippet, then deleted the post. The token is still active. The response lead can authorize immediate revocation under the local process; the service owner must coordinate replacement. Misuse has not been established.

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

revocation / rotation / secret store / blast radius / audit log / credential identifier

01 **Sofia:** I deleted the support post as soon as I noticed the token. The page is gone. Can we close the report?

02 **Malik:** No. Removing the post does not perform [1] _____. The token is still active, and someone may already have copied it.

03 **Sofia:** It belongs to the nightly integration. I can identify the credential record without pasting its value into this chat.

04 **Malik:** Use that [2] _____. I am authorizing revocation through our response process now. Notify the owner that dependent work may be interrupted.

05 **Sofia:** I have sent the identifier through the restricted case channel. The owner is joining, and the revocation action has been submitted.

06 **Malik:** Record when it is actually confirmed. Requested and disabled are different states; we should not claim the token is unusable until the result is verified.

07 **Sofia:** Revocation is now confirmed. The owner says a replacement is needed before the next run. Can we put the new value in the configuration ticket?

08 **Malik:** No. Use the approved [3] _____. The ticket can reference the controlled record and owner without containing the replacement secret.

09 **Sofia:** The integration still has to retrieve it. I will coordinate that change with the owner and verify the approved consumer can authenticate.

10 **Malik:** Also confirm that the revoked credential is rejected through the authorized verification process. A successful new connection alone does not establish that the old token stopped working.

Conversation continues on the next page.

Deleting the post does not revoke the credential

CONVERSATION / CONTINUED

11 **Sofia:** That gives us two separate checks. Would this complete the credential rotation, even though the investigation stays open?

12 **Malik:** The [4] _____ can be completed and recorded separately. Do not use that completion to claim there was no earlier unauthorized activity.

13 **Sofia:** The owner found another scheduled job using the same credential. It was missing from our first dependency list.

14 **Malik:** Add it and assess the interruption. That also changes the [5] _____ we understood, so update the impact note rather than leave the first description unqualified.

15 **Sofia:** Should the replacement keep all the old permissions? Some were added for a one-off task months ago.

16 **Malik:** Review the required permissions with the owner. Do not carry unnecessary access forward merely because it was present before the exposure.

17 **Sofia:** The provider records are available for part of the exposure period, but an earlier interval is missing. I found no unexplained use in the available records.

18 **Malik:** Keep that limit beside the [6] _____ result. No unexplained use found in those records is narrower than proof that nobody used the token.

19 **Sofia:** The update will separate post removal, confirmed revocation, replacement work, affected jobs, and the investigation gap. I will not include either secret value.

20 **Malik:** Good. Preserve the relevant evidence through the approved process and keep the case open for the remaining assessment, even when the integration is running again.

CHECK THE GAPS

1. revocation / **2.** credential identifier / **3.** secret store / **4.** rotation / **5.** blast radius / **6.** audit log

Why these answers fit, page 170

A working replacement is treated as proof of containment

A replacement token works for the approved job, but nobody has verified that the exposed token is disabled. General tickets must not contain secret values.

Complete the exchange using each phrase once. Read both roles, then switch roles and repeat with the bank covered.

WORD AND PHRASE BANK

revocation / result / value / operation

01 **Engineer:** The successful job confirms the new token works, not the old token's [1] _____.

02 **Lead:** Verify rejection through the authorized process and record the [2] _____.

03 **Engineer:** The ticket will refer to the controlled record, not include the secret [3] _____.

04 **Lead:** Keep the investigation separate from restored service [4] _____.

CHECK THE GAPS

1. revocation / **2.** result / **3.** value / **4.** operation

Why these answers fit, page 170

Keep the distinction audible

Coordinate credential containment, replacement, and evidence without sharing the secret again.

Language for the next case

A linked service is not automatically in the test scope

scope

Scope defines the approved systems and boundaries; a link from an approved staging service does not add the supplier system to the assessment.

Amara: It is outside the listed scope. Our authorization covers Lab-A, not the supplier environment. Do not test the linked service on that basis.

rules of engagement

Rules of engagement document the permitted assessment activities, boundaries, timing, and handling conditions; they are more specific than a general request to test the application.

Amara: The rules of engagement need to make that boundary clear. I can clarify our requirements, but I cannot grant permission on the supplier's behalf.

test window

The test window is the authorized time interval in the specified time zone; a calendar conversion does not change the agreed start or end.

Amara: Use the stated test window and correct the invitation. Confirm both endpoints with the team before starting, rather than rely on a local display.

stop condition

A stop condition requires pausing specified activity when a defined event occurs; unexpected real customer information triggers the handling and escalation process in this case.

Amara: Follow the agreed stop condition. Pause the affected activity and notify the designated contact. Do not expand access or collect additional customer content to make a stronger demonstration.

point of contact

The point of contact is the designated person for coordination during the assessment; an available, agreed route is necessary for reporting disruption and obtaining instructions.

Amara: Correct. The point of contact must be reachable. Completing the planned steps does not override the agreed interruption procedure.

authorization

Authorization is permission from the appropriate authority for the specific activity; a stakeholder request or technical reachability does not supply it.

Amara: Any expanded activity needs written authorization before it happens. That includes resolving permission for any third-party environment involved.

Read the phrases aloud. Then complete the conversation on the following pages using the word bank.

Conversation

A linked service is not automatically in the test scope

An authorized assessment covers fictional staging service Lab-A from 22:00 to 23:00 UTC using listed methods. It excludes production and third-party systems. Lab-A redirects to a supplier login. The consultant asks whether that login is included; no permission for it is documented.

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

rules of engagement / point of contact / stop condition / test window / authorization / scope

01 **Kenji:** Before we start, Lab-A redirects to the supplier login. Is that service covered by the authorization, or do we stop at the redirect?

02 **Amara:** It is outside the listed [1] _____. Our authorization covers Lab-A, not the supplier environment. Do not test the linked service on that basis.

03 **Kenji:** Understood. I will record the dependency without sending assessment traffic to it. The product team thought a link made it part of our application.

04 **Amara:** The [2] _____ need to make that boundary clear. I can clarify our requirements, but I cannot grant permission on the supplier's behalf.

05 **Kenji:** We also have a list of allowed methods. A stakeholder asked for an availability stress test, which is not on that list.

06 **Amara:** That request does not change the agreement. Route any proposed addition through the authorization process and leave it out of the current assessment.

07 **Kenji:** The window says twenty-two hundred to twenty-three hundred UTC. My local calendar converted it differently because of the time zone setting.

08 **Amara:** Use the stated [3] _____ and correct the invitation. Confirm both endpoints with the team before starting, rather than rely on a local display.

09 **Kenji:** Who can we reach during the window if an unexpected service issue appears? I have your daytime office number only.

10 **Amara:** I will confirm the on-duty contact and escalation route in the approved document. Testing should not begin with an unresolved response contact.

Conversation continues on the next page.

A linked service is not automatically in the test scope

CONVERSATION / CONTINUED

11 **Kenji:** If we unexpectedly encounter real customer information in staging, should we collect a sample to prove the finding?

12 **Amara:** Follow the agreed [4] _____. Pause the affected activity and notify the designated contact. Do not expand access or collect additional customer content to make a stronger demonstration.

13 **Kenji:** We can document the minimal observation through the restricted reporting route and let the response owner direct the handling.

14 **Amara:** Yes. Preserve necessary evidence under the agreed rules without turning an unexpected exposure into unnecessary copying or wider distribution.

15 **Kenji:** And if the system becomes unstable during the approved work, we pause and contact the same on-duty person rather than continue to complete the checklist?

16 **Amara:** Correct. The [5] _____ must be reachable. Completing the planned steps does not override the agreed interruption procedure.

17 **Kenji:** I will send the clarified boundary, UTC window, methods, contacts, and stop conditions for confirmation. We are not starting the new request tonight.

18 **Amara:** Any expanded activity needs written [6] _____ before it happens. That includes resolving permission for any third-party environment involved.

19 **Kenji:** The report will separate tested areas from excluded and untested dependencies. I will not describe a clean Lab-A result as a test of the supplier login.

20 **Amara:** Good. Keep the limitations visible so the assessment answers what was actually examined, not what someone assumed was included.

CHECK THE GAPS

1. scope / **2.** rules of engagement / **3.** test window / **4.** stop condition / **5.** point of contact / **6.** authorization

Why these answers fit, page 172

The approved window is mistaken for unlimited permission

A consultant has permission to assess a named staging system from 20:00 to 21:00 UTC using listed methods. Production and stress testing are excluded.

Complete the exchange using each phrase once. Read both roles, then switch roles and repeat with the bank covered.

WORD AND PHRASE BANK

window / methods / environment / authorization

01 **Owner:** Approval is limited to the named staging [1] _____.

02 **Consultant:** I will work only within the stated UTC [2] _____.

03 **Owner:** Keep the activity within the listed [3] _____.

04 **Consultant:** Any expansion needs separate [4] _____.

CHECK THE GAPS

1. environment / **2.** window / **3.** methods / **4.** authorization

Why these answers fit, page 172

Keep the distinction audible

Clarify testing permission, boundaries, and stop conditions before an assessment begins.

Language for the next case

The supplier has a report, but what does it cover?

reporting period

The reporting period specifies when the described controls were examined; a January-to-June report does not automatically establish their operation in later months.

Dev: First check the reporting period. This Type 2 report covers January through June. It is useful evidence, not a guarantee about every service at every later date.

system boundary

The system boundary identifies the services and components described in the report; the supplier name alone does not bring the later add-on into scope.

Dev: Then the system boundary matters. The report covers Core. We need evidence for the add-on rather than assume the company name extends coverage to it.

complementary user entity controls

Complementary user entity controls are controls expected at the customer that the supplier's control design assumes; receiving the report does not perform those customer responsibilities.

Dev: Those are complementary user entity controls. We need an owner for the applicable customer-side responsibilities, not just a copy of the supplier's report.

carve-out method

The carve-out method excludes the subservice organization's controls from this examination; naming the hosting provider does not mean those controls were tested by this report's auditor.

Dev: Not in the way you are assuming. The report uses the carve-out method for that provider. We must understand the dependency and the separate assurance needed.

test exception

A test exception is a deviation identified in the examined control evidence; its nature, context, and implications must be assessed rather than relabeled automatically as a breach.

Dev: No. A test exception needs context: the control, affected scope, test result, response, and implications for us. Read it alongside the auditor's opinion.

bridge letter

A bridge letter provides management's statement about the intervening period; it does not itself extend the independent auditor's examination or add an excluded product.

Dev: A management bridge letter is additional information, not a new independent examination. Read who made the statement and what it actually covers.

Read the phrases aloud. Then complete the conversation on the following pages using the word bank.

Conversation

The supplier has a report, but what does it cover?

A fictional supplier provides a SOC 2 Type 2 report covering its Core service from January 1 to June 30. An August add-on is outside the described system. The report lists customer-side access reviews and excludes a hosting provider under the carve-out method. Purchasing wants immediate approval.

Complete the numbered gaps. Use each bank entry once; some entries contain several words.

WORD AND PHRASE BANK

test exception / system boundary / carve-out method / reporting period / complementary user entity controls / bridge letter

01 **Lucia:** The supplier sent its SOC 2 report. Can I mark the security review complete and issue the order for Core plus the new add-on?

02 **Dev:** First check the [1] _____. This Type 2 report covers January through June. It is useful evidence, not a guarantee about every service at every later date.

03 **Lucia:** The order includes an add-on introduced in August. The cover has the supplier name, but I do not see that product in the system description.

04 **Dev:** Then the [2] _____ matters. The report covers Core. We need evidence for the add-on rather than assume the company name extends coverage to it.

05 **Lucia:** There is a section asking customers to review their own users' access. I thought the supplier's controls covered all access administration.

06 **Dev:** Those are [3] _____. We need an owner for the applicable customer-side responsibilities, not just a copy of the supplier's report.

07 **Lucia:** I will route that to our service owner. Does the report also examine the hosting provider's controls? Its name appears in the description.

08 **Dev:** Not in the way you are assuming. The report uses the [4] _____ for that provider. We must understand the dependency and the separate assurance needed.

09 **Lucia:** So excluded from this examination does not mean the hosting controls failed. It means this report does not supply that examination evidence.

10 **Dev:** Correct. Do not turn an evidence boundary into an unsupported failure claim. Equally, do not mark the dependency assessed merely because the provider is named.

Conversation continues on the next page.

The supplier has a report, but what does it cover?

CONVERSATION / CONTINUED

11 **Lucia:** One test table records a late access review. Should I describe that as proof the supplier suffered a breach?

12 **Dev:** No. A [5] _____ needs context: the control, affected scope, test result, response, and implications for us. Read it alongside the auditor's opinion.

13 **Lucia:** And an exception is not automatically the same as a qualified opinion? I should not substitute my own label for what the auditor actually concluded.

14 **Dev:** Exactly. Record the actual opinion and findings, then assess their relevance to our intended service and information. A headline badge cannot do that work.

15 **Lucia:** The supplier offers a letter about changes since June. Can that extend the auditor's examination to the present?

16 **Dev:** A management [6] _____ is additional information, not a new independent examination. Read who made the statement and what it actually covers.

17 **Lucia:** I will request the latest relevant assurance and specific information on the August add-on. That is narrower than asking them to repeat every document they have.

18 **Dev:** Good. Also identify our access-review owner and the hosting dependency. Those are different open items, so keep each request connected to its purpose.

19 **Lucia:** The purchasing status will say report received, review in progress, Core scope identified, and add-on evidence outstanding. No final security approval yet.

20 **Dev:** That accurately separates receiving a document from reaching a risk decision. We can acknowledge the useful evidence without extending its conclusions beyond their scope.

CHECK THE GAPS

1. reporting period / **2.** system boundary / **3.** complementary user entity controls / **4.** carve-out method / **5.** test exception / **6.** bridge letter

Why these answers fit, page 174

A supplier name is mistaken for coverage of every product

A report describes service Atlas for January-June. The proposed purchase also includes Nova, introduced in August and absent from the system description.

Complete the exchange using each phrase once. Read both roles, then switch roles and repeat with the bank covered.

WORD AND PHRASE BANK

June / approval / Atlas / Nova

01 **Buyer:** The described service is [1] _____, not every product sold by the supplier.

02 **Reviewer:** The examination ends in [2] _____.

03 **Buyer:** We still need evidence relevant to [3] _____.

04 **Reviewer:** Report receipt is not the same as final risk [4] _____.

CHECK THE GAPS

1. Atlas / **2.** June / **3.** Nova / **4.** approval

Why these answers fit, page 174

Keep the distinction audible

Read assurance scope critically without treating a report as a blanket security guarantee.

01 / Answers and explanations

A / Read the situation

A1. What does the identity log establish?

C. A successful privileged-account sign-in at 02:14 UTC

The log establishes the sign-in event, not the identity or permission behind it.

Return to the exercise, page 4

A2. What is missing from 02:10-02:20 UTC?

A. Application logs

The briefing identifies an application-log gap during the relevant period.

Return to the exercise, page 4

A3. What does the local process require now?

B. Escalation to Luis while correlation continues

The stated process requires prompt escalation without first asserting a confirmed cause.

Return to the exercise, page 4

D / Response choices

D1. Which handoff best fits S14?

D. Successful privileged sign-in; authorization unverified; application-log gap; escalated for investigation.

The correct summary preserves all four facts. The alternatives invent authorization, erase the visibility gap, or delay the required escalation.

Return to the exercise, page 8

D2. Which record would help test the maintenance explanation?

A. A ticket matching this host, account, and authorized task

A relevant authorization record must connect to this event rather than merely exist.

Return to the exercise, page 8

01 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: Initial assessment to decide priority and next handling. Which term fits?

C. triage

A Not here. source address: A network address associated with an observed connection. The usual combination is "investigate a source address".

B Not here. indicator: An observable sign that can support an investigation. The usual combination is "assess an indicator".

C Correct. triage: Initial assessment to decide priority and next handling. The usual combination is "perform security triage".

D Not here. telemetry: System observations collected for monitoring or analysis. The usual combination is "review available telemetry".

Return to the exercise, page 8

D4. Rebuild the exchange from "A successful login is not verified authorization". Anika: "I nearly waited for the owner to reply before calling you. Should I escalate now and keep the maintenance explanation provisional?" Luis: [missing response] Anika: "I also found missing application logs between two ten and two twenty UTC. That interval includes the identity event we are discussing." Which response belongs in the gap?

C. Keep triage moving. Our process requires escalation now, and your uncertainty belongs in the update. We can investigate without accusing the owner or announcing a confirmed intrusion.

A Not here. This line belongs to turn 8, after Anika says: "I also found missing application logs between two ten and two twenty UTC. That interval includes the identity event we are discussing." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 2, after Anika says: "S14 triggered on a privileged sign-in at two fourteen UTC. The address is unfamiliar. I have the identity record, but not an explanation yet." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Luis's response in turn 6. It connects Anika's preceding point with Anika's follow-up. Triage is the initial assessment and handling process that continues while the owner response is pending.

D Not here. This line belongs to turn 4, after Anika says: "There is a maintenance ticket from two to three UTC. The timing overlaps, although I have not matched its host or account to this record." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 8

E / Conversation

1. event

Turn 2. The event is the recorded sign-in, distinct from the conclusion that it was malicious.

01 / Answers and explanations / continued

2. hypothesis

Turn 4. Maintenance is a possible explanation because the timing overlaps, but the relevant match is unverified.

3. triage

Turn 6. Triage is the initial assessment and handling process that continues while the owner response is pending.

4. visibility gap

Turn 8. The missing application logs create a visibility gap that restricts the conclusions available to investigators.

5. anomaly

Turn 10. An unfamiliar address departs from the expected pattern but does not establish malicious ownership or intent.

6. authentication

Turn 12. Authentication concerns the identity check reflected in the successful sign-in, not permission for every subsequent action.

7. authorization

Turn 14. Authorization is permission for the specific action, which requires more than a ticket with overlapping times.

8. case record

Turn 16. The case record preserves the evidence, unanswered questions, and actions for the next analyst.

9. confidence level

Turn 18. The confidence level qualifies the current interpretation and should change with evidence rather than with repeated assertion.

10. correlation

Turn 20. Correlation connects the identity event to relevant ticket and host records to test the competing explanations.

Return to the conversation, page 10

01 / Answers and explanations / continued

F / Accuracy and scope

F1. Why is the log gap relevant?

D. It limits what the team can exclude about application activity.

Missing visibility limits negative conclusions without proving why the records are absent.

Return to the exercise, page 13

F2. Which wording avoids premature blame?

A. The account was used; the operator is not yet verified.

Account activity does not by itself identify the person or their intent.

Return to the exercise, page 13

F / Guided speaking

1. UTC

Analyst: The event time is 05:20 UTC.

Turn 1. The briefing explicitly gives the event time in Coordinated Universal Time.

2. unverified

Lead: The account match remains unverified.

Turn 2. The overlapping maintenance period does not establish the relevant account match.

3. unavailable

Analyst: Application logs are unavailable.

Turn 3. The supplied absence of application logs limits the investigation evidence.

4. received

Lead: The escalation has been received.

Turn 4. The briefing says the shift lead has already received the escalation.

Return to the conversation, page 14

01 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "A successful login is not verified authorization". Anika: "I will request the relevant approval through our internal channel. The ticket number alone is not enough without checking which account and host it covers." Luis: [missing response] Anika: "For the next shift, I will list the identity record, maintenance ticket, unanswered owner request, and missing application interval together in S14." Which response belongs in the gap?

C. Exactly. We need authorization evidence tied to the action. Keep the original event details and identify any later corrections instead of silently rewriting the first report.

A Not here. This line belongs to turn 2, after Anika says: "S14 triggered on a privileged sign-in at two fourteen UTC. The address is unfamiliar. I have the identity record, but not an explanation yet." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 4, after Anika says: "There is a maintenance ticket from two to three UTC. The timing overlaps, although I have not matched its host or account to this record." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Luis's response in turn 14. It connects Anika's preceding point with Anika's follow-up. Authorization is permission for the specific action, which requires more than a ticket with overlapping times.

D Not here. This line belongs to turn 16, after Anika says: "For the next shift, I will list the identity record, maintenance ticket, unanswered owner request, and missing application interval together in S14." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 14

02 / Answers and explanations

A / Read the situation

A1. When was isolation completion verified?

B. 09:22 UTC

The case distinguishes the first report, authorization, completion, and next update.

Return to the exercise, page 16

A2. What is the confirmed operational impact?

D. Billing jobs are paused.

The supplied service effect is paused billing jobs, not wider damage.

Return to the exercise, page 16

A3. What does 09:45 represent?

C. The next update time

The briefing expressly makes 09:45 a communication commitment, not a recovery promise.

Return to the exercise, page 16

D / Response choices

D1. Which timeline is accurate?

C. Report 09:10; isolation authorized 09:18; completion verified 09:22.

The correct timeline preserves the distinct states and supplied timestamps.

Return to the exercise, page 20

D2. Which reply addresses pressure to restore now?

C. Billing is paused; restoration still requires the specified response and service-owner process.

Operational urgency does not remove the restoration conditions stated in the case.

Return to the exercise, page 20

02 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: Removal of incident causes or persistence as applicable. Which term fits?

B. eradication

A Not here. lateral movement: Movement from an initial foothold to other systems. The usual combination is "investigate possible lateral movement".

B Correct. eradication: Removal of incident causes or persistence as applicable. The usual combination is "verify eradication".

C Not here. decision authority: The role permitted to approve a particular action. The usual combination is "confirm decision authority".

D Not here. action log: A time-ordered record of response actions. The usual combination is "maintain the action log".

Return to the exercise, page 20

D4. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "I put nine eighteen as the isolation time in my update. That was only permission to act. I will change it to nine twenty-two." Mara: [missing response] Joel: "Would restarting B7 help us resume sooner? Someone suggested it in the operations channel, but I do not know what investigators still need." Which response belongs in the gap?

C. Please also keep the business impact concrete: billing jobs are paused. We have not established that every related service is affected or that customer data left the environment.

A Not here. This line belongs to turn 8, after Joel says: "Would restarting B7 help us resume sooner? Someone suggested it in the operations channel, but I do not know what investigators still need." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 14, after Joel says: "The team has also asked whether other hosts are involved. I only have the report about B7, so I have not named additional systems." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Mara's response in turn 6. It connects Joel's preceding point with Joel's follow-up. The confirmed business impact is paused billing jobs, not an assumed broader outage or data loss.

D Not here. This line belongs to turn 20, after Joel says: "My message will say B7 is isolated, billing jobs remain paused, and investigation continues. I will reserve any all-clear for the authorized process." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 20

E / Conversation

1. containment

Turn 2. Containment aims to limit impact; it does not establish that investigation, eradication, or recovery is complete.

02 / Answers and explanations / continued

2. action log

Turn 4. The action log records the report, authorization, and verified execution as separate events.

3. business impact

Turn 6. The confirmed business impact is paused billing jobs, not an assumed broader outage or data loss.

4. Evidence preservation

Turn 8. Evidence preservation protects relevant information from loss or alteration while response decisions are coordinated.

5. decision authority

Turn 10. The local process assigns restoration decisions to the response lead and service owner, not any individual requesting speed.

6. Eradication

Turn 12. Eradication concerns removing the incident cause or persistence as applicable and is distinct from isolating a host.

7. incident scope

Turn 14. Incident scope covers the systems and effects under investigation; it remains incomplete in this case.

8. status update

Turn 16. The agreed status update commits the team to communicate at 09:45 without promising restoration by then.

9. handover

Turn 18. The handover transfers the current evidence, decisions, impact, and outstanding work to the incoming team.

10. Recovery

Turn 20. Recovery is the controlled restoration of affected capabilities and is not established merely by isolation.

Return to the conversation, page 22

02 / Answers and explanations / continued

F / Accuracy and scope

F1. Which statement about data access is justified?

A. Unauthorized data access has not been confirmed.

The case leaves data access unresolved rather than establishing either extreme.

Return to the exercise, page 25

F2. What belongs in the handover?

B. Actions, timestamps, impact, open questions, and responsible roles

These items preserve usable continuity without inventing conclusions or authority.

Return to the exercise, page 25

F / Guided speaking

1. 11:05

Coordinator: Isolation was authorized at 11:05 UTC.

Turn 1. The briefing assigns 11:05 to authorization rather than to completion.

2. 11:09

Owner: Completion was verified at 11:09 UTC.

Turn 2. The verified completion occurred four minutes after the recorded authorization.

3. 11:30

Coordinator: Our next update is at 11:30 UTC.

Turn 3. The supplied time is a communication commitment, not automatic recovery permission.

4. unauthorized

Owner: Recovery remains unauthorized.

Turn 4. The briefing explicitly states that recovery has not been authorized.

Return to the conversation, page 26

02 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "The team has also asked whether other hosts are involved. I only have the report about B7, so I have not named additional systems." Mara: [missing response] Joel: "What can I promise for nine forty-five: an update, or a working service? People will read the time as a restoration deadline unless I spell it out." Which response belongs in the gap?

B. Keep the incident scope open in the update. One known host does not prove that there are no others, but uncertainty is not evidence that all systems are affected.

A Not here. This line belongs to turn 8, after Joel says: "Would restarting B7 help us resume sooner? Someone suggested it in the operations channel, but I do not know what investigators still need." It addresses that point, not the missing turn in the supplied exchange.

B Correct. This is Mara's response in turn 14. It connects Joel's preceding point with Joel's follow-up. Incident scope covers the systems and effects under investigation; it remains incomplete in this case.

C Not here. This line belongs to turn 16, after Joel says: "What can I promise for nine forty-five: an update, or a working service? People will read the time as a restoration deadline unless I spell it out." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 6, after Joel says: "I put nine eighteen as the isolation time in my update. That was only permission to act. I will change it to nine twenty-two." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 26

03 / Answers and explanations

A / Read the situation

A1. Which finding comes first under the stated tie-break rule?

A. A, the exposed production gateway flaw

The stated rule favors A because external exposure and demonstrated exploitation are supplied.

Return to the exercise, page 29

A2. What does the threat bulletin establish?

D. The flaw has been exploited elsewhere.

Exploitation elsewhere is relevant evidence but does not prove a local incident.

Return to the exercise, page 29

A3. What remains required after selecting A first?

B. Testing, change approval, and verification

Prioritization orders the work without completing the required change and verification steps.

Return to the exercise, page 29

D / Response choices

D1. Which explanation is strongest for A first?

A. Equal scores; A adds external exposure and validated exploitation evidence under the agreed rule.

The correct explanation uses the actual differentiators without inventing a score or incident.

Return to the exercise, page 33

D2. Which statement about B is accurate?

D. It is lower in this ordering but still requires handling.

The tie-break changes priority, not the existence or eventual handling of B.

Return to the exercise, page 33

03 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: A severity score based on intrinsic vulnerability characteristics. Which term fits?

B. base score

A Not here. mitigation: A measure intended to reduce exposure or impact. The usual combination is "verify a mitigation".

B Correct. base score: A severity score based on intrinsic vulnerability characteristics. The usual combination is "compare base scores".

C Not here. false finding: A reported weakness not supported after validation. The usual combination is "investigate a false finding".

D Not here. asset criticality: The importance of an asset to organizational objectives. The usual combination is "assess asset criticality".

Return to the exercise, page 33

D4. Rebuild the exchange from "The same score, a different repair priority". Petra: "The bulletin says the gateway flaw has been used against other organizations. Does that mean we should announce an incident in our own environment?" Chen: [missing response] Petra: "Fine, A first. Can we leave B assigned and visible? I do not want lower priority to turn into nobody owning the test-server fix." Which response belongs in the gap?

A. No. It establishes exploitation in the wild, not local compromise. We should preserve that distinction while using the verified information as a reason to prioritize corrective work.

A Correct. This is Chen's response in turn 6. It connects Petra's preceding point with Petra's follow-up. Real-world exploitation elsewhere supports prioritization but does not by itself establish local compromise.

B Not here. This line belongs to turn 18, after Petra says: "After installation, what evidence do you need to close the finding? I can attach the change record, but we still need to verify the affected condition." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 2, after Petra says: "Both findings are eight point eight. The operations queue usually sorts by score, so I need a clear reason to move the gateway ahead." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 8, after Petra says: "Fine, A first. Can we leave B assigned and visible? I do not want lower priority to turn into nobody owning the test-server fix." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 33

E / Conversation

1. base score

Turn 2. The base score reflects intrinsic severity characteristics and does not include every relevant local risk factor.

03 / Answers and explanations / continued

2. internet-facing

Turn 4. Internet-facing identifies A's external exposure, which differentiates it from the isolated test system.

3. exploitation in the wild

Turn 6. Real-world exploitation elsewhere supports prioritization but does not by itself establish local compromise.

4. remediation

Turn 8. Remediation is the corrective work still required for both findings, even though A comes first.

5. change approval

Turn 10. Change approval authorizes the defined operational change; a security priority does not automatically supply that permission.

6. regression test

Turn 12. A regression test checks that applying the change has not broken existing behavior required by the service.

7. mitigation

Turn 14. A mitigation reduces a defined exposure or impact and need not remove the underlying software weakness.

8. risk acceptance

Turn 16. Risk acceptance is an authorized decision concerning a specified retained risk, not an informal label that erases the weakness.

9. closure evidence

Turn 18. Closure evidence demonstrates that the required completion conditions were actually met after the change.

10. asset criticality

Turn 20. Asset criticality adds the importance of the production gateway to the context of the prioritization discussion.

Return to the conversation, page 35

03 / Answers and explanations / continued

F / Accuracy and scope

F1. What distinguishes a patch from a mitigation?

A. A patch changes software; another control may reduce exposure without correcting that software.

The distinction concerns how the weakness or its exposure is addressed.

Return to the exercise, page 37

F2. Which closure message is supported before any deployment?

B. A is prioritized; deployment and verification are still pending.

Available patches and selected priorities do not establish completed remediation.

Return to the exercise, page 37

F / Guided speaking

1. X

Analyst: The first priority is X.

Turn 1. The supplied tie-break rule favors the exposed flaw with demonstrated exploitation.

2. equal

Owner: The base scores are equal.

Turn 2. The case explicitly makes the base severity scores the same.

3. elsewhere

Analyst: Exploitation is verified elsewhere.

Turn 3. The supplied evidence describes exploitation elsewhere, not a confirmed local incident.

4. pending

Owner: Deployment is still pending.

Turn 4. The briefing says deployment has not started despite patch availability.

Return to the conversation, page 38

03 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "The same score, a different repair priority". Petra: "If we cannot deploy immediately, the service owner may propose a temporary control. I want the wording to make clear what that would actually achieve." Chen: [missing response] Petra: "Any delay would need the owner, rationale, and review conditions required by our process. An informal note saying accepted would be too vague." Which response belongs in the gap?

C. Describe it as a mitigation with a defined scope and verification. Do not claim that reducing one access path automatically corrects the underlying software or removes every route.

A Not here. This line belongs to turn 2, after Petra says: "Both findings are eight point eight. The operations queue usually sorts by score, so I need a clear reason to move the gateway ahead." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 10, after Petra says: "A patch is available for each. The gateway update may interrupt production, so we still need the service team involved in timing and checks." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Chen's response in turn 14. It connects Petra's preceding point with Petra's follow-up. A mitigation reduces a defined exposure or impact and need not remove the underlying software weakness.

D Not here. This line belongs to turn 6, after Petra says: "The bulletin says the gateway flaw has been used against other organizations. Does that mean we should announce an incident in our own environment?" It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 38

04 / Answers and explanations

A / Read the situation

A1. What does the diagnostic task require?

A. Read access to sanitized logs for two hours

The briefing supplies a narrow read-only task with a defined two-hour duration.

Return to the exercise, page 40

A2. Which local requirement is explicit?

A. Named identities with multifactor authentication, approval, and expiry

These four conditions are stated in the fictional local access policy.

Return to the exercise, page 40

A3. What is the current approval status?

A. Not granted

The briefing explicitly says no approval has yet been granted.

Return to the exercise, page 40

D / Response choices

D1. Which proposal best matches the supplied task and policy?

A. Named read-only log access for two hours, with MFA and owner approval

The correct proposal preserves individual identity, task-limited permission, authentication, approval, and duration. Each alternative changes one required boundary.

Return to the exercise, page 44

D2. Why does MFA not settle the request?

A. It strengthens identity verification but does not justify unnecessary permissions.

Authentication strength and permission scope address different questions in access decisions.

Return to the exercise, page 44

04 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: An account used by more than one individual. Which term fits?

B. shared account

A Not here. multifactor authentication: Verification using more than one distinct factor type. The usual combination is "require multifactor authentication".

B Correct. shared account: An account used by more than one individual. The usual combination is "review shared-account risk".

C Not here. separation of duties: Dividing sensitive responsibilities to reduce conflicting control. The usual combination is "maintain separation of duties".

D Not here. time-bound access: Permission with a defined end time or duration. The usual combination is "approve time-bound access".

Return to the exercise, page 44

D4. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "They will take turns during the two hours. Can one account cover both, or do we need two identities even for that short window?" Rashid: [missing response] Eva: "I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?" Which response belongs in the gap?

A. Our policy requires a named account for each technician. A private agreement about sharing does not replace individual attribution or the access conditions we have been asked to enforce.

A Correct. This is Rashid's response in turn 6. It connects Eva's preceding point with Eva's follow-up. A named account associates access with an identified technician, as required by the stated local policy.

B Not here. This line belongs to turn 14, after Eva says: "If their diagnosis later shows that a configuration change is needed, I will ask them to describe the new action and why it is necessary." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 8, after Eva says: "I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?" It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 2, after Eva says: "Two vendor technicians need to investigate the service issue. They asked for a shared administrator account so either person can begin when available." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 44

E / Conversation

1. least privilege

Turn 2. Least privilege ties the permissions to the actual authorized task rather than to the broadest convenient account.

04 / Answers and explanations / continued

2. read-only access

Turn 4. Read-only access matches inspection of the supplied diagnostic logs without adding unsupported write or administrative rights.

3. named account

Turn 6. A named account associates access with an identified technician, as required by the stated local policy.

4. multifactor authentication

Turn 8. Multifactor authentication is the explicit local sign-in condition and is separate from the task's permission scope.

5. time-bound access

Turn 10. Time-bound access records a limited period of need instead of granting ongoing privilege for a short task.

6. Provisioning

Turn 12. Provisioning enables the access, but the case still requires owner approval before that approved arrangement can be implemented.

7. entitlement

Turn 14. An entitlement is a particular permission; adding write authority changes the access requested and needs reassessment.

8. Accountability

Turn 16. Accountability preserves a connection between actions and individual identities rather than making an accusation about intentions.

9. expiry

Turn 18. Expiry specifies when the permission ends, making the temporary access boundary concrete and reviewable.

10. deprovisioning

Turn 20. Deprovisioning removes or disables access after the approved need ends rather than leaving an unused permission active.

Return to the conversation, page 46

04 / Answers and explanations / continued

F / Accuracy and scope

F1. What should happen if a write task emerges?

A. Submit the additional need for a separate assessment.

The original facts justify only reading, and the briefing requires a separate request for writes.

Return to the exercise, page 50

F2. Which explanation avoids blaming the vendor?

A. The task requires log reading, so we are proposing only that access.

The task-based explanation states a legitimate boundary without making a personal accusation.

Return to the exercise, page 50

F / Guided speaking

1. read-only

Coordinator: The requested permission is read-only.

Turn 1. Viewing the supplied logs does not require writing or administrative permissions.

2. three

Reviewer: The requested duration is three hours.

Turn 2. The briefing explicitly limits the diagnostic task to three hours.

3. named

Coordinator: The identity must be named.

Turn 3. The stated local policy requires an individually identified account.

4. pending

Reviewer: Owner approval remains pending.

Turn 4. The supplied facts say approval has not yet been granted.

Return to the conversation, page 51

04 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "If their diagnosis later shows that a configuration change is needed, I will ask them to describe the new action and why it is necessary." Rashid: [missing response] Eva: "I can explain that this is about fitting access to work, not suggesting that the technicians intend to misuse anything. We still want their support." Which response belongs in the gap?

B. That is a new entitlement question. Do not silently add write access to a request justified only by log reading. The additional need must go through its own assessment.

A Not here. This line belongs to turn 6, after Eva says: "They will take turns during the two hours. Can one account cover both, or do we need two identities even for that short window?" It addresses that point, not the missing turn in the supplied exchange.

B Correct. This is Rashid's response in turn 14. It connects Eva's preceding point with Eva's follow-up. An entitlement is a particular permission; adding write authority changes the access requested and needs reassessment.

C Not here. This line belongs to turn 8, after Eva says: "I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?" It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 2, after Eva says: "Two vendor technicians need to investigate the service issue. They asked for a shared administrator account so either person can begin when available." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 51

05 / Answers and explanations

A / Read the situation

A1. What does the supplied draft already check?

D. The user at sign-in

The draft describes a sign-in check but lacks the separate per-document authorization decision.

Return to the exercise, page 54

A2. What security requirement is supplied?

D. Customers may see only their own organization-owned documents.

The briefing explicitly defines the organization-level document-access boundary.

Return to the exercise, page 54

A3. What is not established?

A. A confirmed breach or implemented-system test result

The discussion concerns the draft design, not an already proven live exploit.

Return to the exercise, page 54

D / Response choices

D1. Which requirement closes the identified design gap?

A. Enforce server-side permission for each requested document.

The missing decision concerns permission for the requested object, not only identity or interface presentation.

Return to the exercise, page 58

D2. Which pair best tests the stated boundary?

B. An authorized same-tenant request and a denied cross-tenant request using controlled data

The pair checks both intended access and the protected boundary within authorized test scope.

Return to the exercise, page 58

05 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: An actor or system outside the modeled component. Which term fits?

D. external entity

A Not here. tenant isolation: Separation preventing unauthorized cross-tenant access. The usual combination is "test tenant isolation".

B Not here. abuse case: A scenario describing misuse of intended functionality. The usual combination is "define an abuse case".

C Not here. tampering: Unauthorized modification of data or system state. The usual combination is "prevent data tampering".

D Correct. external entity: An actor or system outside the modeled component. The usual combination is "identify external entities".

Return to the exercise, page 58

D4. Rebuild the exchange from "A sign-in check does not decide document access". Noor: "So the gap is not simply that somebody could be anonymous. It also concerns a legitimate user asking for a document outside their organization." Daniel: [missing response] Noor: "Could we just hide documents from other organizations in the browser? Or does the service need to enforce the same boundary independently?" Which response belongs in the gap?

A. Exactly. That is the abuse case we should record. It makes the missing decision concrete without claiming that the implemented system has already leaked anything or that a breach occurred.

A Correct. This is Daniel's response in turn 6. It connects Noor's preceding point with Noor's follow-up. The abuse case describes a signed-in user attempting access outside the intended document boundary.

B Not here. This line belongs to turn 8, after Noor says: "Could we just hide documents from other organizations in the browser? Or does the service need to enforce the same boundary independently?" It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 12, after Noor says: "I will put both outcomes into the design. Otherwise someone could call the issue fixed by denying every request and breaking the ordinary feature." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 16, after Noor says: "What label goes in the review: confirmed vulnerability or design gap? We have a draft in front of us, not an implementation test." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 58

E / Conversation

1. data flow

Turn 2. The data flow shows how the identifier moves from the browser through the service to storage.

05 / Answers and explanations / continued

2. authorization check

Turn 4. The authorization check decides permission for the requested document, distinct from verifying identity at sign-in.

3. abuse case

Turn 6. The abuse case describes a signed-in user attempting access outside the intended document boundary.

4. trust boundary

Turn 8. The trust boundary separates client-controlled input from the service's responsibility to enforce access decisions.

5. object-level authorization

Turn 10. Object-level authorization applies the permission rule to each specific requested document rather than to sign-in alone.

6. security requirement

Turn 12. A security requirement states a checkable protected outcome while preserving the intended authorized behavior.

7. tenant isolation

Turn 14. Tenant isolation concerns preventing unauthorized access between customer organizations sharing the service.

8. threat model

Turn 16. The threat model records the design-level threat and response without converting an untested design gap into a confirmed breach.

9. server-side enforcement

Turn 18. Server-side enforcement places the permission decision in the controlled service rather than relying on browser behavior.

10. information disclosure

Turn 20. Information disclosure is unauthorized exposure of document content, the specific harm addressed by this access requirement.

Return to the conversation, page 60

05 / Answers and explanations / continued

F / Accuracy and scope

F1. Which statement overclaims the review evidence?

A. A customer breach has definitely occurred.

The briefing explicitly supplies no confirmed breach or implemented-system test result.

Return to the exercise, page 64

F2. Why is a browser-supplied ID not enough?

C. A value naming an object does not establish permission to access it.

Identifying a document and authorizing access to it are separate functions.

Return to the exercise, page 64

F / Guided speaking

1. identity

Architect: The existing check establishes identity.

Turn 1. The supplied design checks the signed-in identity rather than invoice permission.

2. authorization

Security: Each invoice also needs an authorization check.

Turn 2. Authorization determines whether the user may access the particular requested invoice.

3. server

Architect: Enforcement belongs on the server.

Turn 3. The proposed control is enforced by the service, not by client convention.

4. pending

Security: Implementation validation remains pending.

Turn 4. The briefing says no implementation test has yet been performed.

Return to the conversation, page 65

05 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "A sign-in check does not decide document access". Noor: "For validation, we can use two fictional organizations with controlled test accounts and documents in the approved environment. No live customer exploration is needed." Daniel: [missing response] Noor: "What label goes in the review: confirmed vulnerability or design gap? We have a draft in front of us, not an implementation test." Which response belongs in the gap?

A. That supports a tenant isolation check within an authorized scope. Record which account owns which document, the requested action, and the expected result before interpreting the observed outcome.

A Correct. This is Daniel's response in turn 14. It connects Noor's preceding point with Noor's follow-up. Tenant isolation concerns preventing unauthorized access between customer organizations sharing the service.

B Not here. This line belongs to turn 2, after Noor says: "The diagram lists the browser, service, and storage. We require sign-in before the document page, so I thought the main access question was covered." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 8, after Noor says: "Could we just hide documents from other organizations in the browser? Or does the service need to enforce the same boundary independently?" It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 4, after Noor says: "The draft does not say. It describes checking the user at sign-in, then retrieving the requested file. Our customers should see only their own organization's documents." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 65

06 / Answers and explanations

A / Read the situation

A1. How many sampled records prove timely removal?

C. Three of five

Three records contain evidence of removal within the stated twenty-four-hour limit.

Return to the exercise, page 67

A2. What do the other two records lack?

D. Removal timestamps

The briefing identifies missing timestamps rather than confirmed late removals.

Return to the exercise, page 67

A3. Can the finding close under the supplied criteria?

B. No; evidence and owner review are incomplete.

The stated closure conditions require all five cases to be evidenced and owner review recorded.

Return to the exercise, page 67

D / Response choices

D1. Which summary is accurate?

B. Three timely removals are evidenced; two are unverified; owner review is missing.

The correct summary keeps documented timeliness, missing evidence, and missing review separate.

Return to the exercise, page 71

D2. What is 3 divided by 5 in this case?

D. 60% of the sample with documented timely removal

The calculation applies only to the supplied five-item sample and evidence status.

Return to the exercise, page 71

06 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: Whether a control works as intended over the assessed scope. Which term fits?

C. operating effectiveness

A Not here. finding: A documented assessment issue supported by stated criteria and evidence. The usual combination is "track an audit finding".

B Not here. audit trail: Records allowing actions and decisions to be traced. The usual combination is "preserve the audit trail".

C Correct. operating effectiveness: Whether a control works as intended over the assessed scope. The usual combination is "test operating effectiveness".

D Not here. control frequency: How often a control is intended to operate. The usual combination is "specify control frequency".

Return to the exercise, page 71

D4. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "Could I say the control was sixty percent effective? Three out of five is sixty percent, and that seems more concise for the committee." Amir: [missing response] Rosa: "I agree about not calling them late without evidence. The help desk thinks the removals happened, but we do not yet have the original supporting records." Which response belongs in the gap?

D. Report the sample accurately: sixty percent has documented timely removal. That does not establish organization-wide effectiveness, and it does not prove the other two were late.

A Not here. This line belongs to turn 16, after Rosa says: "Could I sign a statement about our normal process? I can describe what the team does, but I cannot supply those two times yet." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 4, after Rosa says: "We selected five leavers. Three records include departure and removal times within the required period. The other two do not include removal timestamps." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 14, after Rosa says: "I will assign the record retrieval and keep the committee wording bounded. For the missing cases, I will use timeliness unverified rather than late." It addresses that point, not the missing turn in the supplied exchange.

D Correct. This is Amir's response in turn 6. It connects Rosa's preceding point with Rosa's follow-up. The sample is the five examined cases, so the percentage must be tied to those records and their evidence status.

Return to the exercise, page 71

06 / Answers and explanations / continued

E / Conversation

1. control design

Turn 2. Control design concerns the planned rule and process, which policy approval supports without proving operation.

2. operating effectiveness

Turn 4. Operating effectiveness concerns actual performance; the incomplete records do not establish it for every sampled case.

3. sample

Turn 6. The sample is the five examined cases, so the percentage must be tied to those records and their evidence status.

4. evidence gap

Turn 8. The evidence gap is the absence of timestamps needed to determine timeliness, not proof of a late action.

5. closure criteria

Turn 10. The closure criteria explicitly require all five cases to be evidenced and owner review recorded.

6. remediation plan

Turn 12. The remediation plan can record completed policy work and the remaining evidence and review tasks without falsely closing the finding.

7. audit trail

Turn 14. The audit trail records what the evidence shows and how later conclusions are reached without overwriting the uncertainty.

8. attestation

Turn 16. An attestation is a formal statement, but it does not replace the source evidence expressly required by these closure criteria.

9. sampling limitation

Turn 18. The sampling limitation prevents the five reviewed cases from being presented as proof about every leaver in the organization.

06 / Answers and explanations / continued

10. control owner

Turn 20. The control owner is responsible for gathering the remaining support and completing the required review in this case.

Return to the conversation, page 73

F / Accuracy and scope

F1. Which evidence request is appropriately specific?

C. Provide source records for the two removal times and the owner review.

The request directly addresses the missing closure evidence without inventing historical facts.

Return to the exercise, page 76

F2. Why should the finding remain open?

D. The agreed evidence and review conditions are not met.

Closure follows the supplied criteria, not personal approval or unsupported accusations.

Return to the exercise, page 76

F / Guided speaking

1. timestamp

Auditor: For the fourth case, we still need the removal timestamp.

Turn 1. The missing removal timestamp is the source evidence needed to compare the action with the deadline.

2. timeliness

Owner: Without it, I cannot verify that case's timeliness.

Turn 2. Timeliness is unresolved; the missing record does not prove either timely or late removal.

3. review

Auditor: We also need the recorded owner review.

Turn 3. The local closure criteria separately require an owner review that has not been completed.

4. closure

Owner: Keep the finding open until the evidence and review meet our conditions for closure.

Turn 4. Closure depends on both outstanding requirements, not merely the existence of the approved policy.

Return to the conversation, page 77

06 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "I will assign the record retrieval and keep the committee wording bounded. For the missing cases, I will use timeliness unverified rather than late." Amir: [missing response] Rosa: "Could I sign a statement about our normal process? I can describe what the team does, but I cannot supply those two times yet." Which response belongs in the gap?

D. That preserves the audit trail. We need a traceable account of the assessment, including any later records or corrections, not a headline that hides unresolved support.

A Not here. This line belongs to turn 4, after Rosa says: "We selected five leavers. Three records include departure and removal times within the required period. The other two do not include removal timestamps." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 6, after Rosa says: "Could I say the control was sixty percent effective? Three out of five is sixty percent, and that seems more concise for the committee." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 16, after Rosa says: "Could I sign a statement about our normal process? I can describe what the team does, but I cannot supply those two times yet." It addresses that point, not the missing turn in the supplied exchange.

D Correct. This is Amir's response in turn 14. It connects Rosa's preceding point with Rosa's follow-up. The audit trail records what the evidence shows and how later conclusions are reached without overwriting the uncertainty.

Return to the exercise, page 77

07 / Answers and explanations

A / Read the situation

A1. What did Ben report doing?

D. Clicking the link without entering credentials, opening an attachment, or approving a prompt

The briefing gives a link click and explicitly excludes the other reported actions.

Return to the exercise, page 81

A2. How long after the click did Ben report it?

C. Four minutes

The time from 09:32 to 09:36 UTC is four minutes.

Return to the exercise, page 81

A3. What is the message status?

C. Not yet classified

The briefing leaves both message classification and compromise unestablished.

Return to the exercise, page 81

D / Response choices

D1. Which opening is most useful?

B. Thank you for reporting. What actions did you take, and when?

The useful opening encourages disclosure and gathers facts without blame or secret collection.

Return to the exercise, page 85

D2. Which status accurately reflects the facts?

B. A suspicious-message report is under assessment; compromise is not established.

Neither message classification nor compromise has been established in the supplied case.

Return to the exercise, page 85

07 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: Pretending to be a trusted person or organization. Which term fits?

D. impersonation

A Not here. link destination: The address to which a link points. The usual combination is "assess the link destination".

B Not here. message classification: An assessed category assigned to a message. The usual combination is "confirm message classification".

C Not here. out-of-band verification: Checking through a separate trusted communication route. The usual combination is "use out-of-band verification".

D Correct. impersonation: Pretending to be a trusted person or organization. The usual combination is "assess possible impersonation".

Return to the exercise, page 85

D4. Rebuild the exchange from "Report the click, without guessing the consequence". Ben: "I clicked at nine thirty-two UTC and reported it at nine thirty-six. A page opened. I did not type anything into it." Leila: [missing response] Ben: "No credentials, no attachment, and no prompt approval. I can give you my password if that helps you check whether the account was affected." Which response belongs in the gap?

B. I will record the interaction history. Did you enter credentials, open an attachment, or approve a sign-in prompt? Those are separate actions, and we need each one described accurately.

A Not here. This line belongs to turn 8, after Ben says: "No credentials, no attachment, and no prompt approval. I can give you my password if that helps you check whether the account was affected." It addresses that point, not the missing turn in the supplied exchange.

B Correct. This is Leila's response in turn 6. It connects Ben's preceding point with Ben's follow-up. The interaction history distinguishes the click from later actions such as entering data, opening files, or approving prompts.

C Not here. This line belongs to turn 12, after Ben says: "Understood. I still have the original email. Should I forward it to everyone in my department so they can recognize it and avoid clicking?" It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 4, after Ben says: "The email said I needed to confirm payroll information urgently. It showed Payroll as the sender name, so I assumed it came from our team." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 85

07 / Answers and explanations / continued

E / Conversation

1. reporting promptly

Turn 2. Thanking the employee for reporting promptly encourages factual disclosure without blame or promises about employment outcomes.

2. display name

Turn 4. The display name is the visible sender label, which does not by itself establish that the message is genuine.

3. interaction history

Turn 6. The interaction history distinguishes the click from later actions such as entering data, opening files, or approving prompts.

4. credential

Turn 8. A credential supports authentication and should not be disclosed during this factual intake conversation.

5. compromise

Turn 10. Compromise is not confirmed, but the absence of reported credential entry alone does not prove that no risk exists.

6. reporting tool

Turn 12. The reporting tool is the stated route for submitting the original message without spreading it through an ordinary distribution list.

7. out-of-band verification

Turn 14. Out-of-band verification uses a separate trusted route rather than contact details supplied by the suspicious communication.

8. reporting delay

Turn 16. The reporting delay is four minutes between the supplied click and report times, not a measure of confirmed harm.

9. intake

Turn 18. Intake gathers the relevant facts needed for assessment; omitting the click would distort the response team's understanding.

07 / Answers and explanations / continued

10. Message classification

Turn 20. Message classification remains pending until assessment determines the appropriate category; a familiar label does not settle it.

Return to the conversation, page 87

F / Accuracy and scope

F1. What should Ben use to submit the original?

A. The approved reporting tool

The briefing specifies the approved reporting tool and says to avoid further interaction.

Return to the exercise, page 89

F2. Which confirmation route avoids trusting the suspicious message?

D. A previously verified Payroll contact channel

An independent known channel does not rely on contact details supplied by the suspect message.

Return to the exercise, page 89

F / Guided speaking

1. seven

Responder: The reporting interval was seven minutes.

Turn 1. The interval from 14:10 to 14:17 UTC is seven minutes.

2. credential

Employee: I report no credential entry.

Turn 2. The supplied fact concerns credential entry rather than every possible interaction or risk.

3. pending

Responder: Message classification is pending.

Turn 3. The briefing explicitly leaves message classification unresolved at this stage.

4. tool

Employee: I will use the approved reporting tool.

Turn 4. The local process specifies the approved tool as the reporting route.

Return to the conversation, page 90

07 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "Report the click, without guessing the consequence". Ben: "I will use that route. The message also gives a phone number for Payroll. Should I call that number to ask whether they sent it?" Leila: [missing response] Ben: "I can reach Payroll through our established internal contact. For the security report, I will keep the times and the original message available." Which response belongs in the gap?

A. Use out-of-band verification through a Payroll channel you already know is genuine. A number supplied only in the suspicious message would rely on the same unverified source.

A Correct. This is Leila's response in turn 14. It connects Ben's preceding point with Ben's follow-up. Out-of-band verification uses a separate trusted route rather than contact details supplied by the suspicious communication.

B Not here. This line belongs to turn 4, after Ben says: "The email said I needed to confirm payroll information urgently. It showed Payroll as the sender name, so I assumed it came from our team." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 8, after Ben says: "No credentials, no attachment, and no prompt approval. I can give you my password if that helps you check whether the account was affected." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 16, after Ben says: "I can reach Payroll through our established internal contact. For the security report, I will keep the times and the original message available." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 90

08 / Answers and explanations

A / Read the situation

A1. How far did the test exceed the recovery-time objective?

D. Two hours

Six hours of observed recovery minus the four-hour objective equals two hours.

Return to the exercise, page 91

A2. What does the 800-record illustration mean?

A. Deferred processing during four hours at the assumed rate

Four hours multiplied by two hundred records per hour gives deferred processing, not proven loss.

Return to the exercise, page 91

A3. What decision is requested?

B. $30,000 for recovery automation and repeat testing

The briefing identifies proposal A and its defined funding purpose.

Return to the exercise, page 91

D / Response choices

D1. Which opening is most decision-ready?

A. A six-hour recovery test missed the four-hour objective; I request $30,000 to automate and retest.

The strongest opening connects evidence, target, action, and amount without inventing an incident.

Return to the exercise, page 95

D2. Which statement about data loss is supported?

C. The supplied test does not establish data loss.

Recovery duration and data-loss evidence are distinct, and loss is not established here.

Return to the exercise, page 95

08 / Answers and explanations / continued

D3. A colleague needs the term for this meaning: An assessment of how probable an event is. Which term fits?

D. likelihood

A Not here. recovery test: A controlled exercise of restoration capabilities. The usual combination is "run a recovery test".

B Not here. investment case: Reasons, costs, and expected outcomes supporting expenditure. The usual combination is "present an investment case".

C Not here. risk appetite: The amount and type of risk an organization is willing to pursue or retain. The usual combination is "clarify risk appetite".

D Correct. likelihood: An assessment of how probable an event is. The usual combination is "qualify the likelihood estimate".

Return to the exercise, page 95

D4. Rebuild the exchange from "A recovery shortfall needs a bounded decision". Victor: "Then explain the business consequence in operational terms. I want the committee to understand the exposure without hearing an unsupported claim about a current attack." Imani: [missing response] Victor: "That is a useful scale. But eight hundred records does not mean eight hundred customers permanently lost, or eight hundred dollars of lost revenue." Which response belongs in the gap?

B. A service interruption would delay payroll processing. At the stated rate of two hundred scheduled records per hour, a four-hour interruption would defer eight hundred records.

A Not here. This line belongs to turn 16, after Victor says: "If the repeat test meets four hours, what risk remains? I need that limitation in the committee note, not just the improvement headline." It addresses that point, not the missing turn in the supplied exchange.

B Correct. This is Imani's response in turn 6. It connects Victor's preceding point with Victor's follow-up. The service interruption is a conditional disruption used to explain the operational consequence, not an event currently occurring.

C Not here. This line belongs to turn 8, after Victor says: "That is a useful scale. But eight hundred records does not mean eight hundred customers permanently lost, or eight hundred dollars of lost revenue." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 14, after Victor says: "How will we know whether the automation works? A purchase receipt will show spending, but it will not show that recovery has become faster." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 95

E / Conversation

1. recovery test

Turn 2. The recovery test supplies the measured six-hour restoration result, distinct from a live incident or a forecast.

08 / Answers and explanations / continued

2. recovery-time objective

Turn 4. The recovery-time objective is the restoration-time target and does not itself measure data loss.

3. service interruption

Turn 6. The service interruption is a conditional disruption used to explain the operational consequence, not an event currently occurring.

4. deferred processing

Turn 8. Deferred processing means delayed work under the supplied rate assumption, not proven permanent loss or lost revenue.

5. funding envelope

Turn 10. The funding envelope is the defined thirty-thousand-dollar request for the stated automation and repeat-testing scope.

6. risk treatment

Turn 12. The proposed risk treatment targets the demonstrated recovery shortfall, which the dashboard alternative does not directly address.

7. success measure

Turn 14. The success measure is recovery performance against the existing four-hour objective in the agreed repeat test.

8. Residual exposure

Turn 16. Residual exposure is the risk remaining outside or after this specific improvement, so the proposal is not a complete risk-elimination claim.

9. assurance evidence

Turn 18. Assurance evidence supports the claim that the improved recovery capability actually works after the proposed changes.

10. decision request

Turn 20. The decision request asks the authorized sponsor to approve or decline the defined proposal rather than reporting approval as already granted.

Return to the conversation, page 97

08 / Answers and explanations / continued

F / Accuracy and scope

F1. Why does A rank ahead under the stated priority?

C. It directly addresses the evidenced payroll recovery shortfall.

The agreed priority is the measured recovery gap, not price or blanket dismissal of alternatives.

Return to the exercise, page 101

F2. What should follow the proposed automation?

C. Repeat the agreed recovery test and assess evidence against the objective.

A proposed capability improvement needs verification against the defined recovery objective.

Return to the exercise, page 101

F / Guided speaking

1. two

Security: The test exceeded the objective by two hours.

Turn 1. Five hours minus the three-hour objective equals a two-hour excess.

2. 100

Sponsor: The illustration uses 100 records per hour.

Turn 2. The briefing supplies an assumed processing rate of one hundred records per hour.

3. 300

Security: Three hours would defer 300 records.

Turn 3. Three hours multiplied by one hundred scheduled records per hour equals three hundred.

4. unestablished

Sponsor: Data loss remains unestablished.

Turn 4. The briefing supplies no evidence establishing data loss from the recovery test.

Return to the conversation, page 102

08 / Answers and explanations / continued

F / Rebuild the exchange

1. Rebuild the exchange from "A recovery shortfall needs a bounded decision". Victor: "How will we know whether the automation works? A purchase receipt will show spending, but it will not show that recovery has become faster." Imani: [missing response] Victor: "If the repeat test meets four hours, what risk remains? I need that limitation in the committee note, not just the improvement headline." Which response belongs in the gap?

C. The success measure is performance in the agreed repeat test against the four-hour objective. We need that evidence before claiming that the restoration capability meets the target.

A Not here. This line belongs to turn 6, after Victor says: "Then explain the business consequence in operational terms. I want the committee to understand the exposure without hearing an unsupported claim about a current attack." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 2, after Victor says: "The proposal lists several technical weaknesses. I need to know what decision you want and why this work comes before the dashboard upgrade." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Imani's response in turn 14. It connects Victor's preceding point with Victor's follow-up. The success measure is recovery performance against the existing four-hour objective in the agreed repeat test.

D Not here. This line belongs to turn 8, after Victor says: "That is a useful scale. But eight hundred records does not mean eight hundred customers permanently lost, or eight hundred dollars of lost revenue." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 102

Review 1 / Explanations

Cumulative review

1. A colleague needs the term for this meaning: An occurrence assessed as compromising or threatening security. Which term fits?

A. incident

A Correct. incident: An occurrence assessed as compromising or threatening security. The usual combination is "classify an incident".

B Not here. log source: A system or service producing event records. The usual combination is "identify the log source".

C Not here. authorization: Permission for a particular action or resource. The usual combination is "confirm authorization".

D Not here. benign activity: Activity assessed as not harmful in its context. The usual combination is "confirm benign activity".

Return to the exercise, page 27

2. A colleague needs the term for this meaning: Agreed guidance for handling a defined situation. Which term fits?

A. playbook

A Correct. playbook: Agreed guidance for handling a defined situation. The usual combination is "follow the approved playbook".

B Not here. affected host: A system within the known impact or investigation scope. The usual combination is "identify the affected host".

C Not here. incident response: Coordinated handling of a suspected or confirmed security incident. The usual combination is "coordinate incident response".

D Not here. business impact: A consequence for organizational operations or objectives. The usual combination is "report business impact".

Return to the exercise, page 27

Review 1 / Explanations / continued

3. Rebuild the exchange from "A successful login is not verified authorization". Anika: "The dashboard says new address. Is that enough to label the source hostile, or should I just report that it is unfamiliar?" Luis: [missing response] Anika: "Understood. I will say that the identity log records success, the source is unfamiliar, and the account holder has not confirmed the activity." Which response belongs in the gap?

B. Call it an anomaly. It deserves investigation, but novelty does not establish who controlled the connection. The maintenance explanation still needs testing, just as the hostile explanation does.

A Not here. This line belongs to turn 2, after Anika says: "S14 triggered on a privileged sign-in at two fourteen UTC. The address is unfamiliar. I have the identity record, but not an explanation yet." It addresses that point, not the missing turn in the supplied exchange.

B Correct. This is Luis's response in turn 10. It connects Anika's preceding point with Anika's follow-up. An unfamiliar address departs from the expected pattern but does not establish malicious ownership or intent.

C Not here. This line belongs to turn 8, after Anika says: "I also found missing application logs between two ten and two twenty UTC. That interval includes the identity event we are discussing." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 6, after Anika says: "I nearly waited for the owner to reply before calling you. Should I escalate now and keep the maintenance explanation provisional?" It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 27

Review 1 / Explanations / continued

4. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "I will say that plainly. I also need the next shift to understand what was authorized and which checks are still open when they arrive." Mara: [missing response] Joel: "My message will say B7 is isolated, billing jobs remain paused, and investigation continues. I will reserve any all-clear for the authorized process." Which response belongs in the gap?

D. Use the handover record, including timestamps, owners, and outstanding decisions. They should not have to infer permission from a short chat message or an optimistic headline.

A Not here. This line belongs to turn 2, after Joel says: "Billing is paused, and the team wants a restoration time. We know B7 is isolated. Can I tell them the incident is now over?" It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 20, after Joel says: "My message will say B7 is isolated, billing jobs remain paused, and investigation continues. I will reserve any all-clear for the authorized process." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 12, after Joel says: "I can explain the business impact and available operational options. I cannot certify from isolation alone that the underlying problem has been removed." It addresses that point, not the missing turn in the supplied exchange.

D Correct. This is Mara's response in turn 18. It connects Joel's preceding point with Joel's follow-up. The handover transfers the current evidence, decisions, impact, and outstanding work to the incoming team.

Return to the exercise, page 27

Review 2 / Explanations

Cumulative review

1. A colleague needs the term for this meaning: Common Vulnerability Scoring System, a severity framework. Which term fits?

A. CVSS

A Correct. CVSS: Common Vulnerability Scoring System, a severity framework. The usual combination is "interpret a CVSS score".

B Not here. remediation: Work to resolve an identified weakness or problem. The usual combination is "prioritize remediation".

C Not here. rescan: A follow-up scan to reassess a finding. The usual combination is "perform a rescan".

D Not here. internet-facing: Reachable through an internet-exposed service or interface. The usual combination is "inventory internet-facing assets".

Return to the exercise, page 52

2. A colleague needs the term for this meaning: Permissions assigned through defined job or task roles. Which term fits?

A. role-based access

A Correct. role-based access: Permissions assigned through defined job or task roles. The usual combination is "configure role-based access".

B Not here. identity and access management: Processes for managing identities and their permissions. The usual combination is "review identity and access management".

C Not here. session record: Information documenting a particular access session. The usual combination is "review session records".

D Not here. deprovisioning: Removing or disabling access that is no longer needed. The usual combination is "verify deprovisioning".

Return to the exercise, page 52

Review 2 / Explanations / continued

3. Rebuild the exchange from "Isolation is complete; the investigation is not". Joel: "I will stop treating restart as a routine operations decision here. Who needs to agree before this service can return under our process?" Mara: [missing response] Joel: "I can explain the business impact and available operational options. I cannot certify from isolation alone that the underlying problem has been removed." Which response belongs in the gap?

A. The decision authority includes the response lead and you as service owner. Technical checks and operational consequences need to be assessed together before restoration.

A Correct. This is Mara's response in turn 10. It connects Joel's preceding point with Joel's follow-up. The local process assigns restoration decisions to the response lead and service owner, not any individual requesting speed.

B Not here. This line belongs to turn 12, after Joel says: "I can explain the business impact and available operational options. I cannot certify from isolation alone that the underlying problem has been removed." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 4, after Joel says: "Give me the timeline so I can explain the interruption. I have nine ten in the report and nine eighteen in the response channel." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 2, after Joel says: "Billing is paused, and the team wants a restoration time. We know B7 is isolated. Can I tell them the incident is now over?" It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 52

Review 2 / Explanations / continued

4. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "I will put the identities, read-only log scope, multifactor requirement, two-hour duration, and owner decision in the request. What should I say about the end?" Rashid: [missing response] Eva: "Then I will send the bounded proposal for owner review and avoid promising administrator access. Any changed task will return with a specific justification." Which response belongs in the gap?

B. Record the expiry and confirm how it will be enforced. The access should not remain active simply because everyone assumes somebody else will remove it later.

A Not here. This line belongs to turn 16, after Eva says: "I can explain that this is about fitting access to work, not suggesting that the technicians intend to misuse anything. We still want their support." It addresses that point, not the missing turn in the supplied exchange.

B Correct. This is Rashid's response in turn 18. It connects Eva's preceding point with Eva's follow-up. Expiry specifies when the permission ends, making the temporary access boundary concrete and reviewable.

C Not here. This line belongs to turn 2, after Eva says: "Two vendor technicians need to investigate the service issue. They asked for a shared administrator account so either person can begin when available." It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 12, after Eva says: "I have submitted the request, but the owner has not signed off. What can I tell the technicians while that decision is pending?" It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 52

Review 3 / Explanations

Cumulative review

1. A colleague needs the term for this meaning: A point where assumptions about control or trust change. Which term fits?

B. trust boundary

A Not here. spoofing: Misrepresenting an identity or source. The usual combination is "assess spoofing threats".

B Correct. trust boundary: A point where assumptions about control or trust change. The usual combination is "identify a trust boundary".

C Not here. tenant: A customer or organization sharing a service. The usual combination is "isolate tenant data".

D Not here. entry point: A place where data or interaction enters a system. The usual combination is "review entry points".

Return to the exercise, page 79

2. A colleague needs the term for this meaning: A specified request for records supporting an assessment. Which term fits?

B. evidence request

A Not here. independent review: Assessment by a sufficiently separate reviewer. The usual combination is "conduct an independent review".

B Correct. evidence request: A specified request for records supporting an assessment. The usual combination is "issue an evidence request".

C Not here. governance: Arrangements for directing decisions, responsibilities, and oversight. The usual combination is "strengthen security governance".

D Not here. exception: A departure from a defined requirement or expected condition. The usual combination is "investigate an exception".

Return to the exercise, page 79

Review 3 / Explanations / continued

3. Rebuild the exchange from "Support needs logs, not a shared administrator". Eva: "That gives me the identity and sign-in requirements. For timing, I can specify a two-hour window rather than leaving the access available indefinitely." Rashid: [missing response] Eva: "I have submitted the request, but the owner has not signed off. What can I tell the technicians while that decision is pending?" Which response belongs in the gap?

C. Make it time-bound access with a recorded end. Short work does not justify standing privilege, and the duration should be visible to whoever reviews and implements the request.

A Not here. This line belongs to turn 6, after Eva says: "They will take turns during the two hours. Can one account cover both, or do we need two identities even for that short window?" It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 2, after Eva says: "Two vendor technicians need to investigate the service issue. They asked for a shared administrator account so either person can begin when available." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Rashid's response in turn 10. It connects Eva's preceding point with Eva's follow-up. Time-bound access records a limited period of need instead of granting ongoing privilege for a short task.

D Not here. This line belongs to turn 8, after Eva says: "I will collect both identities. The vendor also says their ordinary login is secure. Does that satisfy our sign-in requirement for this request?" It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 79

Review 3 / Explanations / continued

4. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "Understood. I will separate approval of the policy, evidence for three timely removals, two unverified cases, and the owner review still to be recorded." Amir: [missing response] Rosa: "Then I can give the committee a truthful progress report and a clear remaining action, without claiming that missing documentation proves misconduct or lateness." Which response belongs in the gap?

A. Also state the sampling limitation. We examined five records; we have not established the result for every leaver. The percentage needs both its denominator and its evidence meaning.

A Correct. This is Amir's response in turn 18. It connects Rosa's preceding point with Rosa's follow-up. The sampling limitation prevents the five reviewed cases from being presented as proof about every leaver in the organization.

B Not here. This line belongs to turn 2, after Rosa says: "The new leaver policy is approved. It requires removal within twenty-four hours, and I would like the audit action marked closed before the committee meeting." It addresses that point, not the missing turn in the supplied exchange.

C Not here. This line belongs to turn 12, after Rosa says: "The committee will ask why it is still open. Can we show the approved policy and three supported cases without implying the remaining work is done?" It addresses that point, not the missing turn in the supplied exchange.

D Not here. This line belongs to turn 20, after Rosa says: "Then I can give the committee a truthful progress report and a clear remaining action, without claiming that missing documentation proves misconduct or lateness." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 79

Review 4 / Explanations

Cumulative review

1. A colleague needs the term for this meaning: A claimed reason used to justify a request. Which term fits?

B. pretext

A Not here. message header: Technical metadata associated with an email. The usual combination is "preserve message headers".

B Correct. pretext: A claimed reason used to justify a request. The usual combination is "identify the pretext".

C Not here. interaction history: A factual account of actions taken with content. The usual combination is "record interaction history".

D Not here. urgency cue: Language pressuring someone to act quickly. The usual combination is "identify an urgency cue".

Return to the exercise, page 104

2. A colleague needs the term for this meaning: The target limit on data loss measured in time. Which term fits?

D. recovery-point objective

A Not here. risk scenario: A defined chain of conditions, event, and consequence. The usual combination is "describe a risk scenario".

B Not here. service interruption: A period when a service is unavailable or impaired. The usual combination is "assess service interruption".

C Not here. success measure: A defined basis for judging a proposed outcome. The usual combination is "agree success measures".

D Correct. recovery-point objective: The target limit on data loss measured in time. The usual combination is "distinguish the recovery-point objective".

Return to the exercise, page 104

Review 4 / Explanations / continued

3. Rebuild the exchange from "A written policy does not close the control finding". Rosa: "The closure note says evidence for every sampled case and owner review. I have not completed a recorded review because the two records are still missing." Amir: [missing response] Rosa: "The committee will ask why it is still open. Can we show the approved policy and three supported cases without implying the remaining work is done?" Which response belongs in the gap?

C. Those are the closure criteria we must use. The finding remains open until the missing support and required review are addressed, rather than closing merely because the policy now exists.

A Not here. This line belongs to turn 2, after Rosa says: "The new leaver policy is approved. It requires removal within twenty-four hours, and I would like the audit action marked closed before the committee meeting." It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 12, after Rosa says: "The committee will ask why it is still open. Can we show the approved policy and three supported cases without implying the remaining work is done?" It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Amir's response in turn 10. It connects Rosa's preceding point with Rosa's follow-up. The closure criteria explicitly require all five cases to be evidenced and owner review recorded.

D Not here. This line belongs to turn 8, after Rosa says: "I agree about not calling them late without evidence. The help desk thinks the removals happened, but we do not yet have the original supporting records." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 104

Review 4 / Explanations / continued

4. Rebuild the exchange from "A recovery shortfall needs a bounded decision". Victor: "That distinction belongs in the committee note. We have a measured gap, a conditional operational illustration, a bounded proposal, and a validation requirement." Imani: [missing response] Victor: "I can now evaluate the request against the agreed priority. Please keep the approval status open until I record the decision on that specific scope." Which response belongs in the gap?

C. I will include the assurance evidence expected from the repeat test and identify any implementation dependencies. The recommendation should show what must be demonstrated, not just what we hope to buy.

A Not here. This line belongs to turn 4, after Victor says: "So we missed the target by two hours. Is that a statement about how long payroll data was lost, or how long restoration took?" It addresses that point, not the missing turn in the supplied exchange.

B Not here. This line belongs to turn 20, after Victor says: "I can now evaluate the request against the agreed priority. Please keep the approval status open until I record the decision on that specific scope." It addresses that point, not the missing turn in the supplied exchange.

C Correct. This is Imani's response in turn 18. It connects Victor's preceding point with Victor's follow-up. Assurance evidence supports the claim that the improved recovery capability actually works after the proposed changes.

D Not here. This line belongs to turn 12, after Victor says: "The dashboard is ten thousand dollars cheaper. Why not buy that first? Tell me how each option addresses the gap we actually measured." It addresses that point, not the missing turn in the supplied exchange.

Return to the exercise, page 104

Additional case 1 / Explanations

Extended conversation

1. revocation

Turn 2. Revocation disables the credential itself; deleting a visible copy does not prevent someone who already obtained it from using it.

2. credential identifier

Turn 4. The credential identifier lets responders locate the relevant record without reproducing the authentication secret in another channel.

3. secret store

Turn 8. The secret store is the controlled mechanism for holding and delivering sensitive credentials; a general configuration ticket would create another exposed copy.

4. rotation

Turn 12. Rotation replaces a credential and moves authorized consumers to the replacement; it does not by itself determine whether the exposed credential was misused.

5. blast radius

Turn 14. Blast radius is the scope of affected services or access; discovering another dependent job changes the operational impact assessment.

6. audit log

Turn 18. The audit log provides recorded activity for the available period; missing coverage prevents an unrestricted claim that no misuse occurred.

Return to the conversation, page 107

Transfer exchange

1. revocation

Engineer: The successful job confirms the new token works, not the old token's revocation.

Turn 1. A successful replacement connection does not demonstrate that the exposed credential can no longer authenticate.

Additional case 1 / Explanations / continued

2. result

Lead: Verify rejection through the authorized process and record the result.

Turn 2. The response record needs the actual verification outcome rather than the intended action alone.

3. value

Engineer: The ticket will refer to the controlled record, not include the secret value.

Turn 3. Including the replacement value in a general ticket would create another unnecessary copy of the secret.

4. operation

Lead: Keep the investigation separate from restored service operation.

Turn 4. A running service does not establish whether the exposed credential was misused earlier.

Return to the conversation, page 109

Additional case 2 / Explanations

Extended conversation

1. scope

Turn 2. Scope defines the approved systems and boundaries; a link from an approved staging service does not add the supplier system to the assessment.

2. rules of engagement

Turn 4. Rules of engagement document the permitted assessment activities, boundaries, timing, and handling conditions; they are more specific than a general request to test the application.

3. test window

Turn 8. The test window is the authorized time interval in the specified time zone; a calendar conversion does not change the agreed start or end.

4. stop condition

Turn 12. A stop condition requires pausing specified activity when a defined event occurs; unexpected real customer information triggers the handling and escalation process in this case.

5. point of contact

Turn 16. The point of contact is the designated person for coordination during the assessment; an available, agreed route is necessary for reporting disruption and obtaining instructions.

6. authorization

Turn 18. Authorization is permission from the appropriate authority for the specific activity; a stakeholder request or technical reachability does not supply it.

Return to the conversation, page 111

Transfer exchange

1. environment

Owner: Approval is limited to the named staging environment.

Turn 1. The authorized target is staging; the permitted time does not add production systems.

Additional case 2 / Explanations / continued

2. window

Consultant: I will work only within the stated UTC window.

Turn 2. The approved interval limits when the specified assessment activities may occur.

3. methods

Owner: Keep the activity within the listed methods.

Turn 3. Stress testing is expressly excluded and cannot be added merely because the target and time are approved.

4. authorization

Consultant: Any expansion needs separate authorization.

Turn 4. Changes to targets, time, or activities require the appropriate permission before the expanded work begins.

Return to the conversation, page 113

Additional case 3 / Explanations

Extended conversation

1. reporting period

Turn 2. The reporting period specifies when the described controls were examined; a January-to-June report does not automatically establish their operation in later months.

2. system boundary

Turn 4. The system boundary identifies the services and components described in the report; the supplier name alone does not bring the later add-on into scope.

3. complementary user entity controls

Turn 6. Complementary user entity controls are controls expected at the customer that the supplier's control design assumes; receiving the report does not perform those customer responsibilities.

4. carve-out method

Turn 8. The carve-out method excludes the subservice organization's controls from this examination; naming the hosting provider does not mean those controls were tested by this report's auditor.

5. test exception

Turn 12. A test exception is a deviation identified in the examined control evidence; its nature, context, and implications must be assessed rather than relabeled automatically as a breach.

6. bridge letter

Turn 16. A bridge letter provides management's statement about the intervening period; it does not itself extend the independent auditor's examination or add an excluded product.

Return to the conversation, page 115

Transfer exchange

1. Atlas

Buyer: The described service is Atlas, not every product sold by the supplier.

Turn 1. The supplied system description identifies Atlas and does not include the later product.

Additional case 3 / Explanations / continued

2. June

Reviewer: The examination ends in June.

Turn 2. The stated January-to-June period does not itself cover the later months.

3. Nova

Buyer: We still need evidence relevant to Nova.

Turn 3. Nova is part of the purchase but outside the supplied system description and period.

4. approval

Reviewer: Report receipt is not the same as final risk approval.

Turn 4. Receiving the document leaves the scope gaps and required decision unresolved.

Return to the conversation, page 117

Find a phrase by purpose

Security Triage and Alert Investigation

Lead with the event: "The identity log records a successful sign-in at 02:14 UTC."

Identify the privilege: "The event involves a privileged account."

Separate the conclusion: "Authorization is not yet verified."

Full phrase bank, page 7

Incident Response and Containment

State the current impact: "Billing jobs are paused on B7."

Give the first report: "The activity was first reported at 09:10 UTC."

Separate approval from action: "Isolation was authorized at 09:18."

Full phrase bank, page 19

Vulnerability Management

Acknowledge the tie: "Both findings have a base score of 8.8."

Add the asset context: "A affects the production gateway."

Name the exposure: "That service is internet-facing."

Full phrase bank, page 32

Identity, Access, and Least Privilege

Acknowledge the support need: "We need to enable the diagnostic work."

Clarify the task: "Which action requires administrator rights?"

Use the supplied scope: "The task only needs sanitized diagnostic logs."

Full phrase bank, page 43

Find a phrase by purpose / continued

Threat Modeling and Secure Design

Start with the request: "The browser sends a document identifier to the service."

Trace the next step: "The service retrieves the file from storage."

Name the boundary: "The client-provided identifier crosses a trust boundary."

Full phrase bank, page 57

Governance, Risk, and Compliance

Acknowledge progress: "The new policy has been approved."

Separate design from operation: "That does not yet establish operating effectiveness."

State the criterion: "Access removal is required within 24 hours."

Full phrase bank, page 70

Security Awareness and Phishing

Welcome the report: "Thank you for reporting it promptly."

Ask neutrally: "What did you do after opening the message?"

Locate the event: "What time did you click the link?"

Full phrase bank, page 84

Executive Risk Briefings

Lead with the gap: "The test took six hours against a four-hour objective."

State the difference: "That is a two-hour shortfall against the target."

Separate test from incident: "This is a controlled test result, not a live outage."

Full phrase bank, page 94

Vocabulary index

abuse case
Lesson 05, p. 55

access removal
Lesson 06, p. 69

access review
Lesson 04, p. 42

accountability
Lesson 04, p. 42

action log
Lesson 02, p. 17

affected host
Lesson 02, p. 18

affected version
Lesson 03, p. 30

alert
Lesson 01, p. 5

anomaly
Lesson 01, p. 6

asset
Lesson 05, p. 55

asset criticality
Lesson 03, p. 30

assurance evidence
Lesson 08, p. 93

attachment
Lesson 07, p. 82

attack surface
Lesson 03, p. 30

attestation
Lesson 06, p. 69

audit log
Case 1, p. 106

audit trail
Lesson 06, p. 68

authentication
Lesson 01, p. 5

authentication check
Lesson 05, p. 55

authorization
Lesson 01, p. 5, Case 2, p. 110

authorization check
Lesson 05, p. 55

base score
Lesson 03, p. 30

baseline
Lesson 01, p. 6

benign activity
Lesson 01, p. 6

blast radius
Case 1, p. 106

break-glass access
Lesson 04, p. 42

bridge letter
Case 3, p. 114

business consequence
Lesson 08, p. 92

business impact
Lesson 02, p. 18

carve-out method
Case 3, p. 114

case record
Lesson 01, p. 6

chain of custody
Lesson 02, p. 17

change approval
Lesson 03, p. 31

closure criterion
Lesson 06, p. 69

closure evidence
Lesson 03, p. 31

compensating control
Lesson 03, p. 31

complementary user entity controls
Case 3, p. 114

compromise
Lesson 07, p. 83

confidence level
Lesson 01, p. 6

containment
Lesson 02, p. 17

control design
Lesson 06, p. 68

control frequency
Lesson 06, p. 69

control objective
Lesson 06, p. 68

control owner
Lesson 06, p. 68

Vocabulary index / continued

correlation
Lesson 01, p. 6

credential
Lesson 07, p. 82

credential harvesting
Lesson 07, p. 82

credential identifier
Case 1, p. 106

CVE
Lesson 03, p. 30

CVSS
Lesson 03, p. 30

data flow
Lesson 05, p. 55

data store
Lesson 05, p. 55

decision authority
Lesson 02, p. 18

decision request
Lesson 08, p. 93

deferred processing
Lesson 08, p. 92

denial of service
Lesson 05, p. 56

deprovisioning
Lesson 04, p. 42

display name
Lesson 07, p. 82

document identifier
Lesson 05, p. 56

elevation of privilege
Lesson 05, p. 56

entitlement
Lesson 04, p. 41

entry point
Lesson 05, p. 55

eradication
Lesson 02, p. 17

event
Lesson 01, p. 5

evidence gap
Lesson 06, p. 69

evidence preservation
Lesson 02, p. 17

evidence request
Lesson 06, p. 68

exception
Lesson 06, p. 69

exception expiry
Lesson 03, p. 31

exfiltration
Lesson 02, p. 18

expiry
Lesson 04, p. 42

exploit
Lesson 03, p. 30

exploitation in the wild
Lesson 03, p. 30

external entity
Lesson 05, p. 55

false finding
Lesson 03, p. 31

false positive
Lesson 01, p. 6

federation
Lesson 04, p. 41

finding
Lesson 06, p. 69

funding envelope
Lesson 08, p. 93

governance
Lesson 06, p. 68

handover
Lesson 02, p. 18

hypothesis
Lesson 01, p. 6

identity and access management
Lesson 04, p. 41

impact estimate
Lesson 08, p. 92

impersonation
Lesson 07, p. 82

implementation dependency
Lesson 08, p. 93

incident
Lesson 01, p. 5

incident response
Lesson 02, p. 17

Vocabulary index / continued

incident scope
Lesson 02, p. 18

indicator
Lesson 01, p. 6

intake
Lesson 07, p. 83

internet-facing
Lesson 03, p. 30

just-in-time access
Lesson 04, p. 42

known contact channel
Lesson 07, p. 83

least privilege
Lesson 04, p. 41

likelihood
Lesson 08, p. 92

log source
Lesson 01, p. 6

message classification
Lesson 07, p. 83

MFA prompt
Lesson 07, p. 83

multifactor authentication
Lesson 04, p. 41

network isolation
Lesson 02, p. 17

operating effectiveness
Lesson 06, p. 68

patch
Lesson 03, p. 31

phishing
Lesson 07, p. 82

point of contact
Case 2, p. 110

population
Lesson 06, p. 68

pretext
Lesson 07, p. 82

privileged account
Lesson 01, p. 5

process
Lesson 05, p. 55

provisioning
Lesson 04, p. 41

independent review
Lesson 06, p. 69

information disclosure
Lesson 05, p. 56

interaction history
Lesson 07, p. 83

investment case
Lesson 08, p. 93

KEV catalog
Lesson 03, p. 30

lateral movement
Lesson 02, p. 18

leaver process
Lesson 06, p. 69

link destination
Lesson 07, p. 82

maintenance window
Lesson 01, p. 5

message header
Lesson 07, p. 82

mitigation
Lesson 03, p. 31

named account
Lesson 04, p. 41

object-level authorization
Lesson 05, p. 56

out-of-band verification
Lesson 07, p. 83

persistence
Lesson 02, p. 18

playbook
Lesson 02, p. 17

policy
Lesson 06, p. 68

post-incident review
Lesson 02, p. 18

privileged access
Lesson 04, p. 41

procedure
Lesson 06, p. 68

processing backlog
Lesson 08, p. 92

quarantine
Lesson 07, p. 83

Vocabulary index / continued

reachability
Lesson 03, p. 30

read-only access
Lesson 04, p. 41

recovery
Lesson 02, p. 17

recovery test
Lesson 08, p. 92

recovery-point objective
Lesson 08, p. 92

recovery-time objective
Lesson 08, p. 92

regression test
Lesson 03, p. 31

remediation
Lesson 03, p. 31

remediation plan
Lesson 06, p. 69

remediation window
Lesson 03, p. 31

reply-to address
Lesson 07, p. 82

reporter
Lesson 07, p. 83

reporting delay
Lesson 07, p. 83

reporting period
Case 3, p. 114

reporting tool
Lesson 07, p. 83

rescan
Lesson 03, p. 31

residual exposure
Lesson 08, p. 93

residual risk
Lesson 06, p. 69

resilience
Lesson 08, p. 92

response lead
Lesson 02, p. 17

restoration criterion
Lesson 02, p. 18

retention period
Lesson 06, p. 69

review trigger
Lesson 08, p. 93

revocation
Case 1, p. 106

risk acceptance
Lesson 03, p. 31

risk appetite
Lesson 08, p. 93

risk exposure
Lesson 08, p. 92

risk scenario
Lesson 08, p. 92

risk treatment
Lesson 08, p. 93

role-based access
Lesson 04, p. 41

root cause
Lesson 02, p. 18

rotation
Case 1, p. 106

rules of engagement
Case 2, p. 110

sample
Lesson 06, p. 68

sampling limitation
Lesson 06, p. 68

sanitized logs
Lesson 04, p. 42

scope
Case 2, p. 110

secret store
Case 1, p. 106

security requirement
Lesson 05, p. 55

sender address
Lesson 07, p. 82

separation of duties
Lesson 04, p. 42

server-side enforcement
Lesson 05, p. 56

service account
Lesson 04, p. 42

service interruption
Lesson 08, p. 93

Vocabulary index / continued

service owner
Lesson 02, p. 17

session record
Lesson 04, p. 42

shared account
Lesson 04, p. 41

single sign-on
Lesson 04, p. 41

social engineering
Lesson 07, p. 82

source address
Lesson 01, p. 5

spoofing
Lesson 05, p. 56

standing privilege
Lesson 04, p. 42

status update
Lesson 02, p. 18

stop condition
Case 2, p. 110

STRIDE
Lesson 05, p. 56

success measure
Lesson 08, p. 93

successful sign-in
Lesson 01, p. 5

system boundary
Case 3, p. 114

tampering
Lesson 05, p. 56

telemetry
Lesson 01, p. 6

tenant
Lesson 05, p. 56

tenant isolation
Lesson 05, p. 56

test exception
Case 3, p. 114

test window
Case 2, p. 110

threat model
Lesson 05, p. 55

time-bound access
Lesson 04, p. 42

timestamp
Lesson 01, p. 5

tolerance threshold
Lesson 08, p. 93

triage
Lesson 01, p. 5

trust boundary
Lesson 05, p. 55

uncertainty range
Lesson 08, p. 92

untrusted input
Lesson 05, p. 56

urgency cue
Lesson 07, p. 83

UTC
Lesson 01, p. 5

visibility gap
Lesson 01, p. 6

volatile data
Lesson 02, p. 17

vulnerability
Lesson 03, p. 30

References and publication notes

All cases, organizations, figures, and conversations are fictional teaching material, not transcripts. Communication practice does not replace qualified advice or current workplace procedures.

[1] NIST. SP 800-61 Revision 3: Incident Response Recommendations and Considerations, April 2025.

Background for incident-response vocabulary and the distinction between detection, response, and recovery. The case actions and authority arrangements are fictional. Source checked 30 September 2026.

https://csrc.nist.gov/pubs/sp/800/61/r3/final

[2] CISA. Known Exploited Vulnerabilities Catalog.

Background for using observed exploitation as one prioritization input. No invented vulnerability in this book is represented as an actual catalog entry. Source checked 30 September 2026.

https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[3] OWASP. Threat Modeling Cheat Sheet.

Background for system modeling, data flows, trust boundaries, and testable mitigations. The application and review findings are original fictional cases. Source checked 30 September 2026.

https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html

[4] NIST. SP 800-53 Revision 5: Security and Privacy Controls for Information Systems and Organizations.

Background for access, accountability, assurance, and control vocabulary. The local policies and closure criteria in the exercises are not universal compliance rules. Source checked 30 September 2026.

https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

> **Companion course**
>
> The website offers the eight-lesson course and related practice. This book can be used independently. No audio access or external account is needed for its exercises.
>
> https://englishladder.com/efsp-cybersecurity.html

Report the evidence. Explain the exposure.

Eight security conversations connect technical observations with defensible conclusions, authorized action, and clear business decisions.

Security Triage and Alert Investigation

A successful authentication does not establish that the account holder intended or authorized the action. A matching time window supports a possible maintenance explanation, not a confirmed match to this event.

Incident Response and Containment

09:18 is the authorization time; 09:22 is verified completion. Saying isolated at 09:18 would merge two different events. Record both so later reviewers can reconstruct what actually happened.

Vulnerability Management

A base severity score describes vulnerability characteristics, not the complete risk to a particular organization. Exposure, affected assets, observed exploitation, and local controls can justify different priorities for equal scores.

Identity, Access, and Least Privilege

Authentication checks identity; authorization controls permitted actions. Multifactor authentication does not by itself justify administrator rights. Sanitization also does not remove the stated approval, identity, and expiry requirements.

Phil Stilwell

© 2026 Phil Stilwell. All rights reserved.

No part of this publication may be reproduced, stored in a retrieval system, or transmitted in any form or by any means without prior written permission from the author, except as permitted by law.

English Ladder / English for Work / Revised 2026 edition

This publication includes AI-generated text and cover illustration, revised and checked during production. Brand artwork remains the English Ladder mark. This edition makes no claim of independent professional certification.

Typeface: Bitstream Vera, embedded under its accompanying license. Illustration created with OpenAI's native image generator for this edition. The copyright notice is not a claim to ownership of third-party frameworks or references.